MINISTERE DELEGUE CHARGE DE L'ENSEIGNEMENT SUPERIEUR ET DE LA RECHERCHE SCIENTIFIQUE (MDESRS)

REPUBLIQUE TOGOLAISE
Travail-Liberté-Patrie



ECOLE SUPERIEURE DE GESTION D'INFORMATIQUE ET DES SCIENCES

MEMOIRE PROFESSIONNEL

EN VUE DE L'OBTENTION DU DIPLÔME DE LICENCE PROFESSIONNELLE

Domaine : *Sciences et Technologies*

Mention : *Informatique Réseaux et Télécommunications*

Spécialité: *Sécurité Informatique (SI)*

THEME :

CONCEPTION ET MISE EN ŒUVRE D'UN SYSTÈME DE DÉTECTION ET DE RÉPONSE AUTOMATISÉE CONTRÔLÉE AUX INCIDENTS DE SÉCURITÉ POUR UNE PME À RESSOURCES IT LIMITÉES

Rédigé par : MENSAH Vigniho Gaël

Directeur de mémoire

M. MADJOULBA

ANNEE ACADEMIQUE: 2025 - 2026

MINISTERE DELEGUE CHARGE DE L'ENSEIGNEMENT SUPERIEUR ET DE LA RECHERCHE SCIENTIFIQUE (MDESRS)

REPUBLIQUE TOGOLAISE
Travail-Liberté-Patrie

ECOLE SUPERIEURE DE GESTION D'INFORMATIQUE ET DES SCIENCES

MEMOIRE PROFESSIONNEL

EN VUE DE L'OBTENTION DU DIPLÔME DE LICENCE PROFESSIONNELLE

Domaine : *Sciences et Technologies*

Mention : *Informatique Réseaux et Télécommunications*

Spécialité: *Sécurité Informatique (SI)*

THEME :

CONCEPTION ET MISE EN ŒUVRE D'UN SYSTÈME DE DÉTECTION ET DE RÉPONSE AUTOMATISÉE CONTRÔLÉE AUX INCIDENTS DE SÉCURITÉ POUR UNE PME À RESSOURCES IT LIMITÉES

Rédigé par: MENSAH Vigniho Gaël

Directeur de mémoire

M. MADJOULBA

ANNEE ACADEMIQUE : 2025 - 2026

DÉDICACES

Je dédie ce travail à mes parents, pour leurs sacrifices, leur soutien indéfectible et les valeurs qu'ils m'ont transmises tout au long de mon parcours. À mes frères et sœurs, pour leur affection, leurs encouragements et la motivation qu'ils m'apportent au quotidien.

À tous, je dédie ce mémoire avec reconnaissance et profonde gratitude.

REMERCIEMENTS

Avant tout développement, je souhaite exprimer mes sincères remerciements à toutes les personnes dont le soutien et les compétences ont contribué à la réalisation de ce travail.

Je tiens à adresser ma profonde gratitude à Monsieur Marcel Macy AKAKPO, Directeur de l'École Supérieure de Gestion d'Informatique et des Sciences (ESGIS), pour la qualité de l'enseignement dispensé ainsi que pour l'opportunité de formation offerte au sein de cette institution. Mes remerciements s'étendent également à l'ensemble des équipes pédagogiques et administratives de l'ESGIS pour leur accompagnement, leur disponibilité et la qualité de leur encadrement tout au long de mon parcours.

Mes sincères remerciements vont également au Professeur JOHNSON Daniel, Directeur académique et pédagogique à ESGIS, ainsi qu'au Docteur GBEDEVI Yvette, Responsable du département Informatique, Réseaux et Télécommunications à ESGIS, pour leur soutien, leur accompagnement et leurs conseils tout au long de mon parcours.

J'exprime ensuite ma reconnaissance à mon superviseur académique, Monsieur MADJOULBA Ghislain, pour son encadrement rigoureux, ses précieux conseils et sa disponibilité, qui ont été déterminants dans la réalisation de ce travail.

Je remercie également les enseignants, chercheurs et professionnels du domaine de la sécurité informatique dont les travaux, les ressources et les échanges ont nourri ma réflexion et ma démarche tout au long de ce projet.

Je témoigne également ma profonde gratitude à ma famille, en particulier à mes parents, pour leur accompagnement constant, leurs conseils éclairés, leur soutien moral indéfectible et leurs encouragements, tout au long de ce parcours académique.

Enfin, j'adresse mes remerciements à mes camarades de promotion et amis pour leur esprit de collaboration et de solidarité. Je tiens aussi à exprimer ma gratitude à toutes les personnes, nommées ou non, qui ont contribué de près ou de loin à mon cheminement.

SOMMAIRE

DÉDICACES i
REMERCIEMENTS ii
SOMMAIRE iii
RÉSUMÉ iv
ABSTRACT v
GLOSSAIRE vi
LISTE DES FIGURES viii
LISTE DES TABLEAUX ix
LISTE DES PARTICIPANTS AU PROJET x
SIGLES ET ABRÉVIATIONS xi
INTRODUCTION GÉNÉRALE 1
1. CONTEXTE GÉNÉRAL 2
2. PROBLÉMATIQUE 3
3. OBJECTIFS DU MEMOIRE 3
4. QUESTIONS ET HYPOTHESES DE RECHERCHE 4
5. IMPORTANCE ET JUSTIFICATION DU SUJET 4
6. ANNONCE DU PLAN 5
PREMIÈRE PARTIE : PRÉSENTATION ET CAHIER DES CHARGES 6
CHAPITRE 1 : PRÉSENTATIONS 7
CHAPITRE 2 : CONTEXTE ET CAHIER DES CHARGES 10
DEUXIÈME PARTIE : ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ 19
CHAPITRE 1 : APPROCHES DE SOLUTIONS 20
CHAPITRE 2 : CONCEPTION DE LA SOLUTION RETENUE 26
CHAPITRE 3 : MISE EN ŒUVRE ET TESTS 33
CHAPITRE 4 : RÉSULTATS, ÉVALUATION FINANCIÈRE ET PERSPECTIVES 40
CONCLUSION GÉNÉRALE 45
BIBLIOGRAPHIE I
ANNEXES II
TABLE DES MATIÈRES VIII

RÉSUMÉ

La transformation numérique des petites et moyennes structures entraîne une dépendance croissante aux systèmes informatiques, aux réseaux et aux services numériques. Cette évolution s'accompagne d'une augmentation des risques liés aux incidents de sécurité, alors que les petites structures disposent souvent de ressources humaines et techniques limitées pour assurer une surveillance continue de leur système d'information.

Dans ce contexte, ce mémoire porte sur la conception et la mise en œuvre d'un système de détection et de réponse automatisée contrôlée aux incidents de sécurité. L'objectif est de proposer une architecture capable de centraliser certains événements de sécurité, de détecter des comportements suspects, de les analyser selon des règles prédéfinies et de déclencher, lorsque les conditions de confiance sont suffisantes, une réponse automatique limitée et réversible.

Le projet ne vise pas à remplacer l'expertise d'un spécialiste en cybersécurité ni à automatiser l'ensemble des décisions de sécurité. Il cherche plutôt à réduire la charge associée au traitement des incidents simples et répétitifs, tout en conservant un contrôle humain sur les situations ambiguës ou présentant un risque élevé. Les tests menés sur neuf scénarios d'attaque réseau et hôte ont permis de vérifier la détection en temps réel, la classification des incidents et la décision de réponse. La solution constitue une preuve de concept : l'exécution des réponses y est simulée et journalisée ; le passage à une réponse réelle et l'élargissement de la couverture de détection constituent ses principales perspectives d'évolution.

Mots-clés : cybersécurité, SIEM, détection d'incidents, réponse automatisée, PME.

ABSTRACT

The digital transformation of small and medium-sized organizations is increasing their dependence on information systems, networks and digital services. This evolution is accompanied by growing security risks, while small organizations often have limited human and technical resources to continuously monitor their information systems.

This thesis focuses on the design and implementation of a controlled automated security incident detection and response system. The objective is to collect security events, detect suspicious activities, analyze them according to predefined rules and trigger a limited and reversible automated response when the level of confidence is sufficient. Tests conducted on nine network and host attack scenarios verified real-time detection, incident classification and the response decision. The solution is a proof of concept: responses are simulated and logged, and moving to a real response, together with broader detection coverage, are its main perspectives.

Keywords: cybersecurity, SIEM, incident detection, automated response, SME.

GLOSSAIRE

Terme	Définition
Actif	Élément du système d'information possédant une valeur pour l'organisation et devant être protégé (poste, serveur, donnée, compte).
Incident de sécurité	Événement susceptible de compromettre la confidentialité, l'intégrité ou la disponibilité du système d'information.
SIEM	Security Information and Event Management : système de collecte, de centralisation et d'analyse des événements de sécurité.
IDS	Intrusion Detection System : système de détection d'intrusion analysant le trafic réseau pour repérer les activités suspectes.
HIDS	Host-based Intrusion Detection System : système de détection fonctionnant sur les postes et serveurs (journaux, fichiers, comptes).
Alerte	Notification générée lorsqu'un événement est jugé suffisamment suspect pour nécessiter une vérification humaine.
Réponse automatisée	Action exécutée automatiquement par le système à la suite d'une détection, lorsque le niveau de confiance est suffisant.

Terme	Définition
Réversibilité	Capacité à annuler une action de réponse automatique, afin de revenir à l'état initial en cas de fausse alerte.
Faux positif	Alerte signalant à tort une activité comme malveillante, alors qu'elle est légitime.
Suricata	Outil open-source de détection d'intrusion réseau (IDS) utilisé comme source de détection.
Wazuh	Plateforme open-source de sécurité (SIEM/HIDS) surveillant les postes et serveurs, utilisée comme source de détection.

LISTE DES FIGURES

Figure 1 : Situation géographique de l'ESGIS (Adidogomé, Lomé)..... 8
Figure 2 : Architecture fonctionnelle de la solution de détection et de réponse automatisée .. 27
Figure 3 : Cycle de vie d'un incident, de la détection à la clôture (avec réversibilité)..... 28
Figure 4 : Tableau de bord de la solution présentant les incidents détectés..... 34
Figure 5 : Détection en temps réel d'une attaque et réponse automatique réversible..... 38
Figure 6 : Environnement de mise en œuvre de la solution III
Figure 7 : Résultat d'un scénario de test sur le tableau de bord VII

LISTE DES TABLEAUX

Tableau 1 : Liste des participants x
Tableau 2 : Matrice d'évaluation et de criticité des risques de sécurité de la PME 16
Tableau 3 : Tableau comparatif des approches de détection et de réponse aux incidents 23
Tableau 4 : Synthèse des scénarios de test et des réactions de la plateforme 35
Tableau 5 : Évaluation financière comparative des approches 42
Tableau 6 : Principaux paramètres de détection et de décision de la solution IV
Tableau 7 : Rapport synthétique des tests réalisés V

LISTE DES PARTICIPANTS AU PROJET

Tableau 1 : Liste des participants

Nom et Prénoms	**Rôle / Fonction**	**Structure**
MENSAH Vigniho Gaël	Étudiant, concepteur et réalisateur du projet	ESGIS
M. MADJOULBA	Superviseur de mémoire	ESGIS

SIGLES ET ABRÉVIATIONS

Sigle	Signification
ENISA	Agence de l'Union européenne pour la cybersécurité
ESGIS	École Supérieure de Gestion d'Informatique et des Sciences
HIDS	Host-based Intrusion Detection System : détection d'intrusion sur les hôtes
IDS	Intrusion Detection System : détection d'intrusion réseau
IPS	Intrusion Prevention System : prévention d'intrusion
LMD	Licence-Master-Doctorat
MESR	Ministère de l'Enseignement Supérieur et de la Recherche
NIST	National Institute of Standards and Technology
PME	Petites et Moyennes Entreprises
SI	Sécurité Informatique
SIEM	Security Information and Event Management
SOC	Security Operations Center : centre opérationnel de sécurité
SOAR	Security Orchestration, Automation and Response

INTRODUCTION GÉNÉRALE

1. CONTEXTE GÉNÉRAL

La transformation numérique des petites et moyennes entreprises (PME) s'est fortement accélérée ces dernières années. Ces structures dépendent désormais de leurs systèmes informatiques, de leurs réseaux et de leurs services numériques pour assurer leur activité quotidienne. Cette dépendance accrue s'accompagne d'une exposition grandissante aux menaces de cybersécurité : tentatives d'intrusion, logiciels malveillants, vol de données, attaques par force brute ou par déni de service.

Contrairement aux grandes organisations, les PME disposent rarement d'un personnel spécialisé en sécurité informatique ni des moyens nécessaires pour exploiter un centre opérationnel de sécurité (SOC). La surveillance de leur système d'information repose le plus souvent sur un personnel informatique généraliste, polyvalent mais non spécialisé, qui manque de temps et d'outils adaptés pour détecter et traiter efficacement les incidents.

C'est dans ce contexte que s'inscrit le présent travail, qui porte sur la conception et la mise en œuvre d'un système de détection et de réponse automatisée contrôlée aux incidents de sécurité, pensé pour être accessible à un personnel IT généraliste de PME.

Les rapports récents sur l'état de la menace confirment ce constat. Les petites et moyennes entreprises figurent aujourd'hui parmi les cibles les plus exposées, précisément parce qu'elles concentrent des données de valeur tout en disposant de défenses limitées (ENISA, 2024). Or, une intrusion non détectée à temps peut interrompre l'activité, entraîner la perte de données et porter durablement atteinte à la réputation de la structure. La question n'est donc plus de savoir si une PME sera visée, mais quand elle le sera et avec quels moyens elle pourra réagir.

Le défi est double. Il ne suffit pas de détecter les incidents : encore faut-il pouvoir y réagir rapidement, alors même que la PME ne dispose ni d'un spécialiste de la sécurité, ni d'un budget pour un service externalisé. C'est à ce double défi, détecter et réagir sans expertise pointue ni coût élevé, que le présent mémoire entend répondre.

2. PROBLÉMATIQUE

Dans quelle mesure un système de détection et de réponse automatisée aux incidents de sécurité, conçu pour être opéré par un personnel IT généraliste d'une petite structure, peut-il réduire la charge et le niveau d'expertise requis pour détecter et traiter certains incidents, sans compromettre la fiabilité de la réponse ?

Cette problématique soulève plusieurs questions subsidiaires. Quels événements de sécurité peut-on détecter de manière fiable à partir de sources réelles accessibles à une PME ? Selon quels critères décider qu'un incident peut être traité automatiquement plutôt que soumis à une vérification humaine ? Et comment automatiser une réaction sans priver l'opérateur de la maîtrise finale des décisions ? C'est à ces questions que les chapitres suivants apportent des éléments de réponse.

3. OBJECTIFS DU MEMOIRE

Afin d'apporter une réponse opérationnelle à la problématique identifiée, le projet est structuré autour d'un objectif général décliné en objectifs spécifiques.

3.1. Objectif général

L'objectif de ce mémoire est de concevoir et de mettre en œuvre un système de détection et de réponse automatisée contrôlée aux incidents de sécurité, adapté aux contraintes d'une PME. La solution vise à centraliser des événements de sécurité réels, à détecter les comportements suspects, à les analyser selon des règles prédéfinies et à déclencher, lorsque le niveau de confiance est suffisant, une réponse automatique limitée et réversible, tout en restant utilisable par un personnel informatique non spécialisé.

3.2. Objectifs spécifiques

Pour atteindre cet objectif général, les objectifs spécifiques suivants ont été retenus :

Collecter et centraliser des événements de sécurité issus de sources réelles, couvrant à la fois le réseau et les postes ou serveurs de l'organisation ;

Détecter les comportements suspects et calculer, pour chaque événement, un niveau de confiance et de gravité ;

Décider automatiquement, selon des règles de confiance et de gravité, entre une réponse automatique et une alerte nécessitant une vérification humaine ;

Déclencher des réponses automatiques limitées et réversibles, afin de combiner la rapidité de l'automatisation et le maintien du contrôle humain ;
Assurer la gestion du cycle de vie des incidents : enregistrement, qualification et résolution ;
Offrir un tableau de bord accessible à un personnel IT généraliste, présentant les incidents avec des explications et des recommandations en langage clair ;
Évaluer la solution selon sa capacité de détection, son taux de fausses alertes et son utilisabilité pour un non-spécialiste.

4. QUESTIONS ET HYPOTHESES DE RECHERCHE

La conception et l'évaluation de la solution s'appuient sur les hypothèses de recherche suivantes:
H1 : Un personnel IT généraliste dispose des compétences nécessaires pour effectuer des actions de base sur un incident, mais est limité par le temps requis pour la surveillance continue et l'interprétation des événements de sécurité.
H2 : Le couplage d'un mécanisme de détection avec un système de réponse automatisée contrôlée permet de traiter automatiquement une partie des incidents répétitifs et suffisamment caractérisés.
H3 : Rendre les réponses automatiques réversibles permet de concilier la rapidité de réaction et le maintien du contrôle humain, en limitant l'impact d'une éventuelle fausse alerte.

5. IMPORTANCE ET JUSTIFICATION DU SUJET

Ce sujet présente un double intérêt. Sur le plan pratique et professionnel, il propose aux PME une solution de supervision de sécurité construite sur des outils open-source éprouvés, peu coûteuse et utilisable sans expertise pointue, répondant à un besoin réel et largement documenté.
Sur le plan académique et de la sécurité, il illustre concrètement l'application des principes de détection et de réponse aux incidents (SOC, SIEM, SOAR) à un contexte contraint. Il explore en outre une contribution originale : la réversibilité des réponses automatiques, envisagée comme un moyen de concilier l'automatisation de la réaction et le maintien du contrôle humain.
Ce travail présente enfin l'intérêt de confronter des concepts de sécurité souvent réservés aux grandes organisations, tels que le centre opérationnel de sécurité (SOC) ou l'orchestration de la réponse (SOAR), aux contraintes concrètes d'une petite structure. Il montre qu'une partie de ces principes peut être transposée, à moindre coût, à l'aide d'outils open-source, à condition d'en simplifier l'usage et d'en maîtriser l'automatisation.

6. ANNONCE DU PLAN

Pour répondre à la problématique soulevée et valider nos hypothèses, le présent mémoire est structuré en deux grandes parties, conformément au canevas officiel de l'ESGIS pour la filière Sécurité Informatique.

La première partie pose le cadre du projet : elle présente l'établissement de formation (ESGIS) et le contexte de la cybersécurité des PME, puis dresse l'étude de l'existant, l'analyse des risques et le cahier des charges de l'étude.

La deuxième partie est consacrée à l'étude et à la mise en œuvre de la solution : elle aborde l'étude comparative des approches, la conception de la solution retenue, sa mise en œuvre et ses tests, puis la présentation des résultats, l'évaluation et les recommandations.

PREMIÈRE PARTIE : PRÉSENTATION ET CAHIER DES CHARGES

CHAPITRE 1 : PRÉSENTATIONS

1.1. INTRODUCTION

Ce chapitre présente le cadre académique dans lequel s'inscrit le projet. Il décrit l'établissement de formation, l'École Supérieure de Gestion, d'Informatique et des Sciences (ESGIS), au sein duquel ce mémoire a été réalisé. Le contexte du projet, ses fondements théoriques et le cahier des charges de l'étude sont présentés au chapitre suivant.

1.2. PRESENTATION DE L'ETABLISSEMENT DE FORMATION (ESGIS)

L'École Supérieure de Gestion, d'Informatique et des Sciences (ESGIS) est un établissement privé d'enseignement supérieur fondé avec pour ambition de former des cadres qualifiés et directement opérationnels dans les domaines des sciences technologiques, du management et de l'ingénierie informatique.

Sur le plan géographique, l'ESGIS est implantée à Adidogomé, un quartier de Lomé, la capitale du Togo. Le site se trouve le long du boulevard du 30 Août, non loin du boulevard Faure Gnassingbé, comme l'illustre la figure 1 ci-dessous.

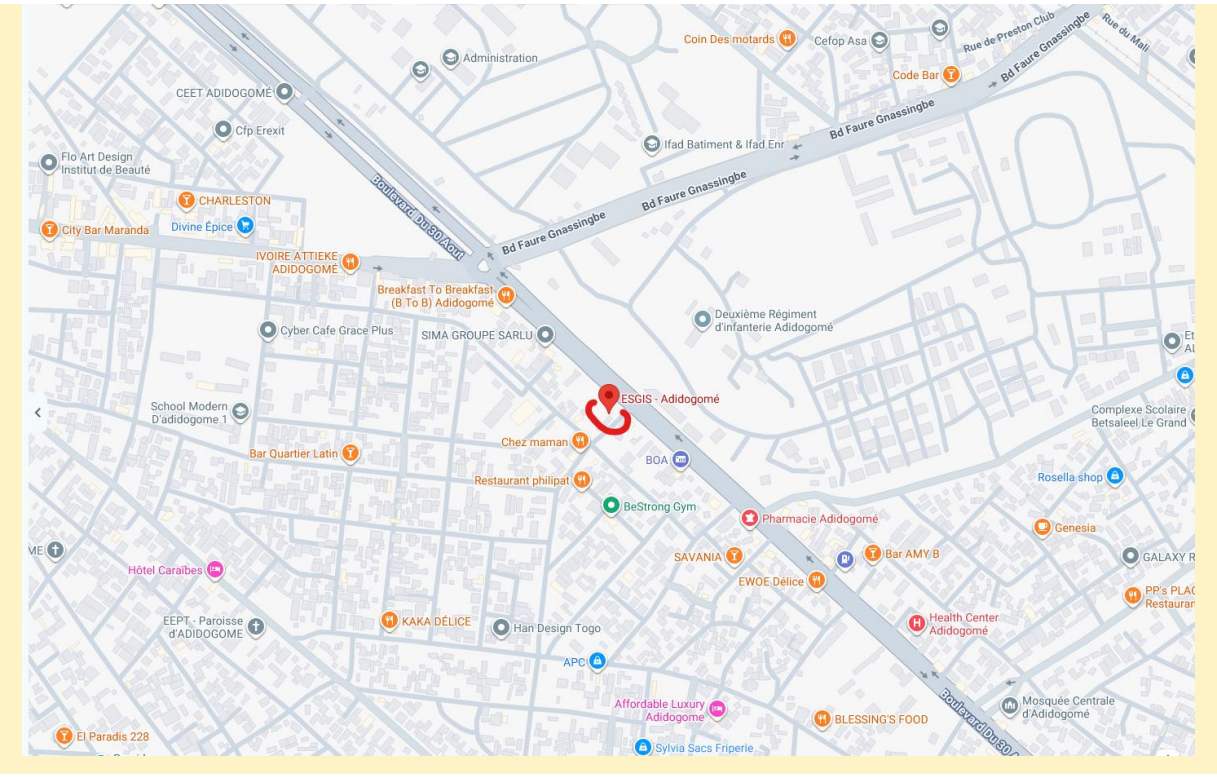


Figure 1 : Situation géographique de l'ESGIS (Adidogomé, Lomé)

Placée sous la tutelle du Ministère de l'Enseignement Supérieur et de la Recherche (MESR) de la République Togolaise, l'ESGIS propose des parcours de Licence et de Master Professionnels

conformes au système LMD (Licence-Master-Doctorat). La filière Sécurité Informatique (SI) s'inscrit au cœur du Département d'Informatique. Elle vise à transmettre aux étudiants une maîtrise approfondie de l'architecture des systèmes, du durcissement des réseaux, de la cryptographie appliquée et de la gouvernance de la sécurité des systèmes d'information.

C'est dans ce cadre de formation, orienté vers la pratique professionnelle, que s'inscrit le présent mémoire. Le projet mobilise les compétences acquises en administration des systèmes, en sécurité des réseaux et en développement, pour concevoir une réponse concrète à un besoin de terrain. Il illustre la vocation de la Licence Professionnelle : passer de la théorie enseignée à une réalisation opérationnelle et évaluable.

1.3. CONCLUSION

Ce chapitre a permis de situer le projet dans son environnement académique, à travers la présentation de l'ESGIS, l'établissement de formation au sein duquel il a été réalisé. Le chapitre suivant présente le contexte de la cybersécurité des petites et moyennes entreprises et les fondements théoriques de la détection et de la réponse aux incidents, puis analyse la situation existante, les risques associés et le cahier des charges de la solution.

CHAPITRE 2 : CONTEXTE ET CAHIER DES CHARGES

2.1. INTRODUCTION

Ce chapitre présente le contexte dans lequel s'inscrit le projet. Il expose d'abord le contexte de la cybersécurité des petites et moyennes entreprises et les fondements théoriques de la détection et de la réponse aux incidents, puis étudie la situation de sécurité habituellement observée dans les PME : il décrit les pratiques existantes, met en évidence leurs principales limites ainsi que les risques associés, puis définit la problématique, les objectifs et les résultats attendus. Cette analyse permet d'identifier les besoins auxquels doit répondre la solution proposée.

2.2. CONTEXTE DU PROJET : LA CYBERSÉCURITÉ DES PME

Le projet n'a pas été réalisé au sein d'une structure d'accueil spécifique : il s'inscrit dans une démarche académique visant à répondre à une problématique largement observée chez les petites et moyennes entreprises. Cette section présente donc le contexte général de la cybersécurité des PME, qui constitue le cadre de référence du projet.

2.2.1. ENJEUX ET CONTRAINTES DE SÉCURITÉ DES PME

Les petites et moyennes entreprises occupent une place centrale dans le tissu économique, mais constituent aujourd'hui une cible privilégiée des cyberattaques, précisément en raison de leurs défenses souvent limitées. Plusieurs contraintes caractérisent leur situation :

Les menaces auxquelles sont confrontées les PME sont variées et en constante évolution : intrusions à la suite d'une tentative d'accès réussie, attaques par force brute visant les comptes, propagation de logiciels malveillants, hameçonnage, ou encore reconnaissance préalable par balayage du réseau. Selon l'ENISA (2024), ces attaques touchent de plus en plus les petites structures, qui constituent souvent un maillon faible et une porte d'entrée vers de plus grandes organisations. Face à cette diversité, l'enjeu n'est pas seulement de se protéger, mais de disposer d'une capacité de détection et de réaction proportionnée à ses moyens.

Des ressources humaines limitées : l'informatique est fréquemment gérée par une seule personne ou une petite équipe généraliste, sans spécialiste de la sécurité ;

Des ressources financières réduites : les solutions de sécurité commerciales et les services de SOC externalisés représentent un coût difficilement soutenable ;

Un manque de temps et d'outils : la surveillance continue des événements de sécurité et leur interprétation exigent une disponibilité et une expertise rarement disponibles ;

Une exposition croissante : la numérisation des activités augmente la surface d'attaque, alors que les mécanismes de détection et de réaction restent souvent absents ou manuels.

Ces constats justifient le besoin d'une solution de détection et de réponse automatisée, à la fois accessible, peu coûteuse et adaptée aux moyens d'une PME.

2.3. FONDEMENTS THÉORIQUES DE LA DÉTECTION ET DE LA RÉPONSE AUX INCIDENTS

Avant d'étudier les solutions envisageables, il convient de préciser les notions sur lesquelles repose ce travail. Cette section définit les concepts clés de la sécurité des systèmes d'information mobilisés dans le mémoire, puis présente le cycle de traitement d'un incident et les principaux outils de supervision qui en découlent.

2.3.1. NOTIONS FONDAMENTALES

La sécurité d'un système d'information s'organise autour de quelques notions essentielles. Un actif désigne tout élément de valeur à protéger : poste de travail, serveur, donnée, compte d'accès ou service réseau. Une vulnérabilité est une faiblesse susceptible d'être exploitée, tandis qu'une menace représente la cause potentielle d'un incident. Un événement est un fait observable dans le système (une connexion, une tentative d'authentification, un paquet réseau), et devient un incident de sécurité lorsqu'il est susceptible de compromettre la confidentialité, l'intégrité ou la disponibilité du système d'information.

La sécurité vise précisément à préserver ces trois propriétés, souvent résumées par le sigle CID : la confidentialité (seules les personnes autorisées accèdent à l'information), l'intégrité (l'information n'est pas altérée) et la disponibilité (le système reste accessible quand on en a besoin). La détection et la réponse aux incidents, au cœur de ce travail, contribuent directement au maintien de ces trois propriétés.

2.3.2. LE CYCLE DE TRAITEMENT D'UN INCIDENT

La gestion des incidents de sécurité est un processus structuré, formalisé notamment par le guide de référence du National Institute of Standards and Technology (NIST, 2012). Ce processus distingue classiquement quatre grandes phases : la préparation (mise en place des outils et des procédures), la détection et l'analyse (identification et qualification de l'incident), le confinement, l'éradication et la récupération (limitation et correction des effets), puis le retour d'expérience (amélioration continue).

La solution proposée dans ce mémoire se concentre sur les deux phases les plus critiques pour une PME démunie : la détection et l'analyse d'une part, et une forme simplifiée de confinement

d'autre part, à travers une réponse automatique limitée et réversible. Elle transpose ainsi, à l'échelle d'une petite structure, une démarche éprouvée au sein des grandes organisations.

2.3.3. OUTILS DE SUPERVISION DE LA SÉCURITÉ : IDS, HIDS, SIEM, SOC ET SOAR

Plusieurs catégories d'outils soutiennent la détection et la réponse. Un système de détection d'intrusion réseau (IDS, Intrusion Detection System) analyse le trafic afin de repérer les activités suspectes ; lorsqu'il peut également bloquer le trafic, il devient un système de prévention d'intrusion (IPS). Un système de détection fonctionnant au niveau des postes et serveurs est qualifié de HIDS (Host-based IDS) : il surveille les journaux, les fichiers et les comptes de la machine elle-même.

Un SIEM (Security Information and Event Management) centralise, corrèle et analyse les événements de sécurité provenant de sources multiples, offrant une vue d'ensemble que les outils isolés ne permettent pas. Le SIEM constitue habituellement le socle technique d'un centre opérationnel de sécurité (SOC), équipe dédiée à la surveillance continue. Enfin, l'approche SOAR (Security Orchestration, Automation and Response) ajoute à cette surveillance l'automatisation des réactions. Ces dispositifs, puissants mais coûteux et exigeants en expertise, sont rarement à la portée d'une PME, ce qui motive la recherche d'une solution allégée et accessible.

2.3.4. DÉTECTION RÉSEAU ET DÉTECTION HÔTE : LA DÉFENSE EN PROFONDEUR

La détection réseau et la détection hôte sont complémentaires. La première observe ce qui circule entre les machines (scans, tentatives de force brute, trafic anormal) ; la seconde observe ce qui se passe à l'intérieur des machines (échecs d'authentification, création de comptes, élévation de privilèges, modification de fichiers sensibles). Une attaque invisible sur le réseau peut être repérée sur l'hôte, et inversement. Combiner les deux relève du principe de défense en profondeur, selon lequel plusieurs couches de contrôle valent mieux qu'une seule. Ce principe oriente directement la conception de la solution retenue, qui s'appuie sur ces deux niveaux de surveillance.

2.3.5. L'AUTOMATISATION DE LA RÉPONSE ET SA MAÎTRISE

Automatiser la réponse permet de réagir plus vite qu'un opérateur humain et de traiter les incidents répétitifs sans intervention. Cette rapidité comporte toutefois un risque : une réaction

déclenchée à tort, sur la base d'une fausse alerte, peut interrompre un service légitime. La contribution centrale de ce mémoire consiste précisément à concilier automatisation et contrôle, en ne déclenchant une réponse automatique que lorsque l'événement est à la fois très probable et grave, et en rendant cette réponse réversible afin qu'une erreur puisse toujours être annulée. Ce compromis constitue le fil conducteur de la conception présentée dans la deuxième partie.

2.4. ÉTUDE DE L'EXISTANT

L'étude de l'existant porte sur la manière dont les petites structures assurent, en pratique, la surveillance et la protection de leur système d'information. Dans la majorité des cas, cette surveillance est partielle et manuelle : elle repose sur les outils natifs du système d'exploitation (journaux d'événements, pare-feu intégré, antivirus) et sur la vigilance ponctuelle du personnel informatique. Les événements de sécurité ne sont ni centralisés, ni analysés en continu, et la réaction à un incident intervient le plus souvent après coup, lorsque ses effets sont déjà visibles.
Concrètement, la surveillance existante dans une petite structure repose sur quelques dispositifs isolés : les journaux d'événements du système d'exploitation (Observateur d'événements sous Windows, journaux système sous Linux), le pare-feu intégré au système, et un antivirus chargé de détecter les fichiers malveillants connus. Ces outils, utiles individuellement, ne communiquent pas entre eux : chacun produit ses propres alertes, sans corrélation ni vue d'ensemble. L'analyse de ces journaux reste manuelle et ponctuelle, souvent déclenchée seulement après qu'un dysfonctionnement a été constaté.
Cette fragmentation explique que de nombreuses attaques passent inaperçues jusqu'à ce que leurs effets deviennent visibles. La littérature confirme ce diagnostic et souligne l'intérêt des solutions open-source pour y remédier à moindre coût. L'étude comparative menée par Manzoor et al. (2024), publiée dans la revue PLoS ONE, évalue plusieurs systèmes de supervision de sécurité open-source du point de vue de la sécurité et des performances, et montre que ce type de solution offre aux petites et moyennes entreprises un niveau de protection satisfaisant pour un coût de licence nul. Ce constat oriente la recherche d'une solution adaptée, dont le choix précis est établi plus loin dans ce mémoire.
Au-delà des outils, c'est le facteur humain qui est déterminant. Les travaux de l'ENISA (2024) rappellent que les PME manquent le plus souvent de personnel qualifié et de temps pour exploiter des dispositifs de sécurité complexes. Toute solution réaliste doit donc viser non seulement l'efficacité de la détection, mais aussi la simplicité d'usage pour un personnel non spécialisé, ce qui constitue une exigence structurante du présent projet.

2.4.1. ANALYSE DES RISQUES ET VULNERABILITES

L'absence d'un dispositif de détection et de réponse structuré expose les PME à plusieurs risques :

Une détection tardive des incidents : faute de surveillance continue, les attaques (intrusion, force brute, propagation de logiciels malveillants) ne sont souvent repérées qu'après avoir causé des dommages ;

Une dispersion des informations de sécurité : les événements proviennent de sources variées (réseau, postes, serveurs) qui ne sont pas corrélées, ce qui empêche une vision d'ensemble ;

Une surcharge du personnel : le traitement manuel des alertes, souvent nombreuses et répétitives, dépasse la capacité d'un personnel généraliste ;

Un manque de réaction automatisée : en l'absence de mécanisme de réponse, chaque incident nécessite une intervention humaine, ce qui allonge le délai de traitement.

Ces risques se renforcent mutuellement. Une détection tardive laisse le temps à une attaque de se propager, ce qui augmente le volume d'événements à traiter ; ce volume accru sature un personnel déjà limité, qui tarde alors à réagir, ce qui aggrave encore les conséquences. Rompre ce cercle suppose d'agir simultanément sur les trois leviers : détecter plus tôt, corréler les événements pour en réduire le nombre apparent, et automatiser le traitement des cas les plus caractérisés. C'est précisément la logique qui guide la conception de la solution.

2.4.2. ANALYSE CRITIQUE DE L'EXISTANT

L'analyse de ces pratiques met en évidence plusieurs limites. La surveillance manuelle et non centralisée ne permet pas de suivre en temps réel l'état de sécurité du système. Le volume et la répétitivité des événements rendent leur traitement difficile pour un personnel non spécialisé. Enfin, l'absence de réponse automatisée se traduit par des délais de réaction importants. L'étude permet également d'identifier les actifs à protéger : les postes de travail et serveurs, les données de l'entreprise, les comptes et identifiants d'accès, ainsi que les services réseau exposés.

La hiérarchisation de ces actifs oriente les priorités de protection. Les comptes et identifiants d'accès, dont la compromission ouvre la voie à l'ensemble du système, et les serveurs hébergeant les données sensibles, constituent les cibles les plus critiques. Les postes de travail et les services réseau exposés viennent ensuite. Cette hiérarchie justifie que la détection porte en priorité sur les tentatives d'accès non autorisé (force brute, échecs d'authentification) et sur les actions sensibles touchant les comptes (création, élévation de privilèges).

2.4.3. ÉVALUATION ET CRITICITÉ DES RISQUES

À partir des risques identifiés, une évaluation est réalisée selon leur probabilité d'occurrence et leur impact potentiel sur le système d'information de la PME. Cette analyse permet de déterminer leur niveau de criticité et d'orienter les mécanismes à intégrer dans la solution. Elle met notamment en évidence la criticité élevée de la détection tardive des intrusions, des attaques par force brute et de la propagation de logiciels malveillants, qui justifient l'intégration d'une détection en temps réel et d'une capacité de réponse automatisée.

Tableau 2 : Matrice d'évaluation et de criticité des risques de sécurité de la PME

Risque identifié	Probabilité	Impact	Niveau de criticité
Détection tardive d'une intrusion	Élevée	Majeur	Critique
Attaque par force brute sur les accès	Élevée	Majeur	Critique
Propagation d'un logiciel malveillant	Moyenne	Majeur	Élevé
Dispersion et non-corrélation des événements	Élevée	Moyen	Élevé
Surcharge du personnel face au volume d'alertes	Élevée	Moyen	Élevé

2.5. PROBLÉMATIQUE, OBJECTIFS ET RÉSULTATS ATTENDUS

2.5.1. PROBLÉMATIQUE

Au regard des limites et des risques identifiés dans la surveillance habituellement observée au sein des PME, le besoin d'une solution permettant de détecter et de traiter les incidents, tout en restant accessible à un personnel généraliste, se dégage clairement. La problématique du projet peut ainsi être formulée comme suit :

Dans quelle mesure un système de détection et de réponse automatisée aux incidents de sécurité, conçu pour être opéré par un personnel IT généraliste d'une petite structure, peut-il réduire la charge et le niveau d'expertise requis pour détecter et traiter certains incidents, sans compromettre la fiabilité de la réponse ?

2.5.2. OBJECTIFS DU PROJET

Pour répondre à cette problématique, le projet poursuit un objectif général complété par plusieurs objectifs spécifiques.

Objectif général : concevoir et mettre en œuvre un système de détection et de réponse automatisée contrôlée aux incidents de sécurité, utilisable par un personnel IT généraliste de PME.

Objectifs spécifiques :

Centraliser des événements de sécurité provenant du réseau et des postes ou serveurs ;

Détecter les comportements suspects et évaluer leur confiance et leur gravité ;

Décider automatiquement entre une réponse automatique et une alerte pour vérification humaine ;

Mettre en œuvre des réponses automatiques limitées et réversibles ;

Gérer le cycle de vie des incidents et présenter l'information de manière claire et exploitable.

2.5.3. RESULTATS ATTENDUS

La réalisation du projet doit permettre d'obtenir les résultats suivants :

Un système capable de collecter et de centraliser des événements de sécurité réels issus du réseau et des hôtes ;

Un moteur de détection calculant, pour chaque événement, un niveau de confiance et de gravité;

Un mécanisme de décision déclenchant une réponse automatique ou une alerte selon des règles prédéfinies ;

Une capacité de réponse automatique réversible, permettant d'annuler une action en cas de fausse alerte ;

Un tableau de bord accessible à un personnel non spécialisé, présentant les incidents, des explications et des recommandations en langage clair.

2.5.4. BESOINS FONCTIONNELS ET NON FONCTIONNELS

Les besoins fonctionnels décrivent ce que la solution doit faire. Elle doit collecter des événements issus du réseau et des hôtes, calculer pour chaque événement un niveau de confiance et de gravité, décider automatiquement entre une réponse automatique et une alerte, exécuter une réponse réversible pour les cas les plus sûrs, assurer le suivi du cycle de vie de chaque incident, regrouper les événements de même nature, et présenter l'ensemble dans un tableau de bord accompagné d'explications et de recommandations.

Les besoins non fonctionnels précisent la manière dont ces fonctions doivent être rendues. La solution doit être accessible à un personnel IT généraliste (lisibilité des informations, langage clair, codes couleur), peu coûteuse (recours à des outils open-source et à du matériel existant), fiable (réponses maîtrisées et réversibles, traçabilité des actions), sécurisée (accès au tableau de bord protégé par authentification, mots de passe stockés sous forme d'empreinte) et extensible (architecture modulaire permettant d'ajouter des sources ou des scénarios).

2.5.5. CONTRAINTES DU PROJET

La réalisation s'inscrit dans plusieurs contraintes. La contrainte financière impose de n'utiliser que des outils gratuits et du matériel déjà disponible. La contrainte humaine impose une prise en main sans expertise en sécurité. La contrainte technique impose un fonctionnement sur une machine aux ressources modestes, représentative du parc d'une PME. Enfin, la contrainte de sécurité impose que l'automatisation ne puisse jamais interrompre durablement un service légitime, ce qui justifie le caractère limité et réversible des réponses automatiques.

2.6. CONCLUSION

Ce chapitre a permis de présenter le contexte de la cybersécurité des PME et les fondements théoriques de la détection et de la réponse aux incidents, puis d'étudier la situation de sécurité habituellement observée dans les PME, d'en identifier les principales limites ainsi que les risques associés. Cette analyse a conduit à la définition de la problématique, des objectifs et des résultats attendus du projet. Ces éléments constituent le cadre de référence pour la conception d'une solution de détection et de réponse automatisée, accessible et maîtrisée, dont les choix techniques et l'architecture sont présentés dans la suite du mémoire.

DEUXIÈME PARTIE :
ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

DEUXIÈME PARTIE :

ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

CHAPITRE 1 : APPROCHES DE SOLUTIONS

1.1. INTRODUCTION

Ce chapitre étudie les principales approches envisageables pour répondre au besoin de détection et de réponse aux incidents de sécurité dans une PME. Il compare une surveillance manuelle reposant sur les outils natifs, une solution SIEM commerciale ou un SOC externalisé, et une solution open-source à réponse automatisée contrôlée, qui constitue l'approche retenue pour le projet.

La démarche suivie dans cette deuxième partie est progressive. Elle part de l'analyse comparative des approches envisageables afin de retenir la plus adaptée, puis définit la conception de la solution selon une architecture modulaire. Cette conception est ensuite concrétisée par un prototype fonctionnel, dont le comportement est vérifié à travers un protocole de tests reposant sur des attaques réelles. Les résultats de ces tests font enfin l'objet d'une évaluation au regard des objectifs et des hypothèses de départ. Cette méthode, de l'analyse à l'évaluation en passant par le prototypage, assure la cohérence entre le besoin identifié et la solution livrée.

1.2. PRÉSENTATION DES APPROCHES

Afin d'identifier l'approche la mieux adaptée aux besoins techniques, humains et financiers d'une PME, trois approches principales ont été étudiées.

1.2.1. SOLUTION 1 : SURVEILLANCE MANUELLE AVEC LES OUTILS NATIFS

Cette approche repose sur l'utilisation des outils intégrés au système d'exploitation et sur la vigilance du personnel informatique. Le suivi de la sécurité s'effectue manuellement à travers les journaux d'événements, le pare-feu intégré et l'antivirus, sans centralisation ni analyse continue.

Avantages : coût direct nul (aucun achat ni licence), absence d'installation et simplicité de mise en œuvre ;

Limites : absence de centralisation et de surveillance en temps réel, dépendance à la vigilance humaine, difficulté à traiter un volume important d'événements et absence totale de réponse automatisée.

1.2.2. SOLUTION 2 : SIEM COMMERCIAL OU SOC EXTERNALISÉ

Cette approche repose sur l'acquisition d'une solution SIEM commerciale clé en main ou sur la souscription à un centre opérationnel de sécurité (SOC) externalisé. Ces solutions offrent des capacités avancées de collecte, de corrélation et d'analyse des événements.

Avantages : fonctionnalités complètes, puissance d'analyse et support professionnel ;

Limites : coût élevé (licences ou abonnement), complexité d'exploitation, besoin d'une expertise pour la configuration et l'interprétation, et dimensionnement souvent supérieur aux besoins réels d'une PME.

1.2.3. SOLUTION 3 : SIEM OPEN-SOURCE À RÉPONSE AUTOMATISÉE CONTRÔLÉE (SOLUTION RETENUE)

Cette solution repose sur l'association d'outils de détection open-source éprouvés, couvrant à la fois le réseau et les hôtes, complétée par un moteur de décision et de réponse automatisée développé spécifiquement. La détection réseau est assurée par l'IDS Suricata et la détection sur les postes et serveurs par le SIEM/HIDS Wazuh. Les événements collectés alimentent un pipeline commun qui calcule la confiance et la gravité, décide d'une réponse automatique ou d'une alerte, et met en œuvre, pour les cas les plus sûrs, une réponse automatique réversible. Un tableau de bord simplifié, accompagné d'explications et de recommandations, rend la solution utilisable par un personnel non spécialisé.

Avantages : coût faible grâce à l'open-source, couverture réseau et hôte, accessibilité pour un personnel généraliste, réponse automatique réversible et architecture extensible ;

Limites : nécessite une installation et une configuration initiales, et les performances dépendent des ressources de la machine qui héberge la solution.

Le choix d'outils open-source n'est pas seulement motivé par leur gratuité. Il garantit également la transparence du fonctionnement, l'absence de dépendance à un fournisseur unique et une large communauté qui documente et met à jour les règles de détection. L'étude de Manzoor et al. (2024) confirme que ces solutions atteignent, pour un coût nul de licence, un niveau de couverture suffisant pour les besoins d'une PME, Wazuh se distinguant particulièrement par ses performances et l'étendue de ses fonctions.

1.3. SYNTHÈSE COMPARATIVE ET CHOIX DE LA SOLUTION

Afin de justifier le choix de l'approche retenue, les trois solutions sont comparées selon des critères de coût, d'accessibilité pour un personnel non spécialisé, de centralisation des événements, de détection en temps réel, de réponse automatisée et d'adaptation aux contraintes d'une PME.

Chaque critère traduit une exigence identifiée dans le cahier des charges. Le coût mesure l'investissement initial et récurrent. L'accessibilité évalue la facilité d'exploitation par un personnel non spécialisé. La centralisation apprécie la capacité à regrouper les événements des deux sources, réseau et hôte, dans un pipeline commun. La détection en temps réel apprécie la rapidité de repérage des événements dès leur survenue. La réponse automatisée examine la possibilité de réagir sans intervention humaine, et sa maîtrise. L'adaptation aux contraintes d'une PME synthétise l'adéquation globale de l'approche avec les moyens humains, financiers et matériels d'une petite structure.

Tableau 3 : Tableau comparatif des approches de détection et de réponse aux incidents

Critère	**Solution 1 : Surveillance manuelle**	**Solution 2 : SIEM commercial ou SOC externalisé**	**Solution 3 : SIEM open-source à réponse automatisée contrôlée (retenue)**
Coût	Nul : aucun achat ni licence	Élevé : licences ou abonnement	Faible : outils open-source, sans coût de licence
Accessibilité pour un personnel non spécialisé	Simple : outils intégrés au système, mais tout repose sur l'humain	Faible : expertise requise pour la configuration et l'interprétation	Bonne : tableau de bord simplifié, pensé pour un généraliste
Centralisation des événements	Non : journaux dispersés, sans centralisation	Oui : collecte et corrélation avancées	Oui : pipeline commun aux sources réseau et hôte
Détection en temps réel	Non : surveillance manuelle et discontinue	Oui	Oui : Suricata et Wazuh en continu

Critère	Solution 1 : Surveillance manuelle	Solution 2 : SIEM commercial ou SOC externalisé	Solution 3 : SIEM open-source à réponse automatisée contrôlée (retenue)
Réponse automatisée	Non : aucune	Oui, selon l'offre souscrite	Oui : contrôlée, limitée aux actions réversibles
Adaptation aux contraintes d'une PME	Limitée : dépend entièrement de la vigilance humaine	Faible : dimensionnement souvent supérieur aux besoins d'une PME	Forte : conçue pour les moyens humains et financiers d'une PME

Choix de la solution :

La solution 3 a été retenue car elle constitue le meilleur compromis pour répondre aux besoins identifiés. Elle offre une couverture de détection à la fois réseau et hôte, une capacité de réponse automatique réversible, et un coût réduit grâce à l'utilisation d'outils open-source, tout en restant accessible à un personnel IT généraliste. Cette adéquation avec les contraintes des PME justifie son choix pour la conception et la mise en œuvre du projet.

Il convient de préciser que la solution retenue ne prétend pas égaler, en puissance, un SIEM commercial ou un SOC professionnel. Son ambition est différente : offrir à une PME un niveau de protection nettement supérieur à la surveillance manuelle, pour un coût proche de zéro et une exploitation à la portée d'un généraliste. C'est dans ce rapport entre le bénéfice de sécurité apporté et le coût consenti que réside l'intérêt de l'approche.

Critère d'évaluation	Solution 1 : Surveillance manuelle	Solution 2 : SIEM commercial / SOC	Solution 3 : SIEM open-source à réponse automatisée
Coût	Nul (coût direct)	Élevé (licences ou abonnement)	Faible (outils open-source)
Accessibilité pour un non-spécialiste	Faible	Faible (expertise requise)	Élevée (tableau de bord et recommandations)
Centralisation des événements	Non	Oui	Oui (réseau et hôte)

Détection en temps réel	Non	Oui	Oui
Réponse automatisée	Non	Variable selon l'offre	Oui, réversible
Adaptation aux contraintes d'une PME	Limitée	Faible (surdimensionné)	Élevée

1.4. CONCLUSION

Ce chapitre a permis de comparer trois approches de détection et de réponse aux incidents de sécurité applicables au contexte d'une PME : la surveillance manuelle, le SIEM commercial ou SOC externalisé, et la solution open-source à réponse automatisée contrôlée. L'analyse comparative montre que cette dernière répond le mieux aux besoins d'accessibilité, de coût et de sécurité identifiés. Elle constitue ainsi la solution retenue pour la conception et la mise en œuvre du projet.

DEUXIÈME PARTIE :

ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

CHAPITRE 2 : CONCEPTION DE LA SOLUTION RETENUE

DEUXIÈME PARTIE :

ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

2.1. INTRODUCTION

Ce chapitre présente la conception de la solution retenue. Il décrit la politique de sécurité adoptée, l'architecture fonctionnelle de la solution et ses différents modules, les sources de détection utilisées, ainsi que les mécanismes de sécurisation et de contrôle d'accès mis en œuvre.

2.2. POLITIQUE DE SÉCURITÉ DE LA SOLUTION

La conception de la solution repose sur plusieurs principes de sécurité :

Détection en profondeur : la surveillance couvre à la fois le réseau (via l'IDS Suricata) et les postes et serveurs (via le SIEM/HIDS Wazuh), afin de repérer les menaces aussi bien à la périphérie qu'à l'intérieur du système ;

Réponse contrôlée et réversible : une réponse automatique n'est déclenchée que lorsque l'événement est à la fois très probable et grave ; les actions sensibles sont conçues pour être réversibles afin de limiter l'impact d'une fausse alerte ;

Contrôle humain : les cas ambigus ou de gravité moindre sont transmis à l'opérateur pour vérification, de manière à conserver la maîtrise des décisions ;

Protection des accès : l'accès au tableau de bord est protégé par une authentification, et les mots de passe sont stockés sous forme d'empreinte et non en clair.

2.3. ARCHITECTURE FONCTIONNELLE DE LA SOLUTION

La solution repose sur une architecture modulaire qui sépare les différentes fonctions de la chaîne de traitement d'un incident :

Module de détection : reçoit les événements issus des sources de sécurité et calcule, pour chacun, un niveau de confiance et de gravité ;

Module de décision : détermine, selon des règles de confiance et de gravité, s'il convient de déclencher une réponse automatique ou de transmettre une alerte pour vérification humaine ;

Module de réponse : exécute les actions de réponse et, pour les actions réversibles, permet leur annulation ;

Module de gestion des incidents : assure le suivi du cycle de vie de chaque incident (nouveau, confirmé, fausse alerte, résolu) ;

Module de tableau de bord : présente les incidents, leur gravité, des explications et des recommandations en langage clair, et permet à l'opérateur d'agir sur chaque incident.

Les événements proviennent de deux sources réelles complémentaires : l'IDS réseau Suricata, qui analyse le trafic, et le SIEM/HIDS Wazuh, qui surveille les postes et serveurs. Un collecteur assure leur intégration en continu dans le pipeline de traitement.

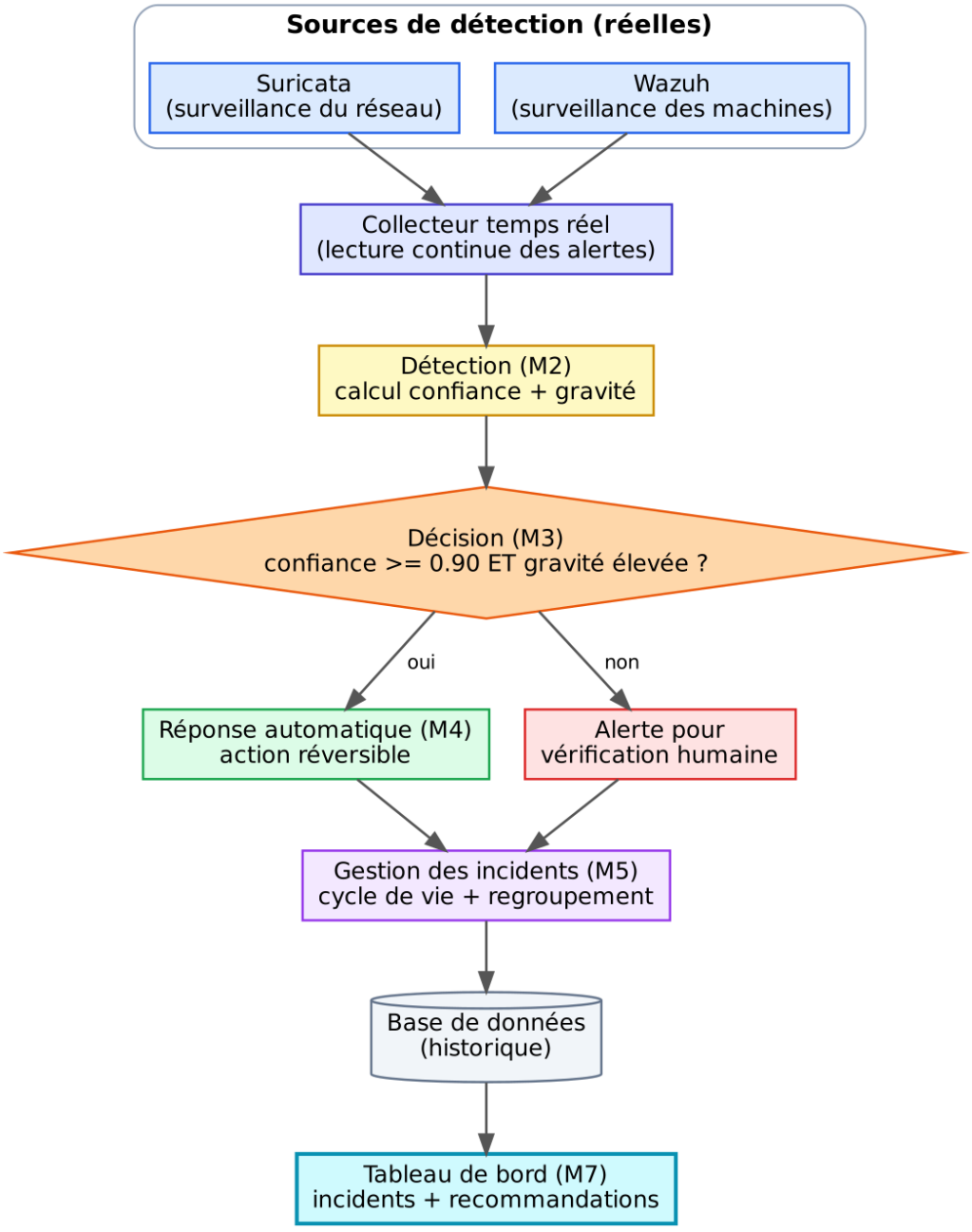


Figure 2 : Architecture fonctionnelle de la solution de détection et de réponse automatisée

Le cycle de vie d'un incident structure son traitement, depuis sa détection jusqu'à sa clôture. L'opérateur confirme une menace avérée ou écarte une fausse alerte ; une action automatique reste réversible à tout moment.

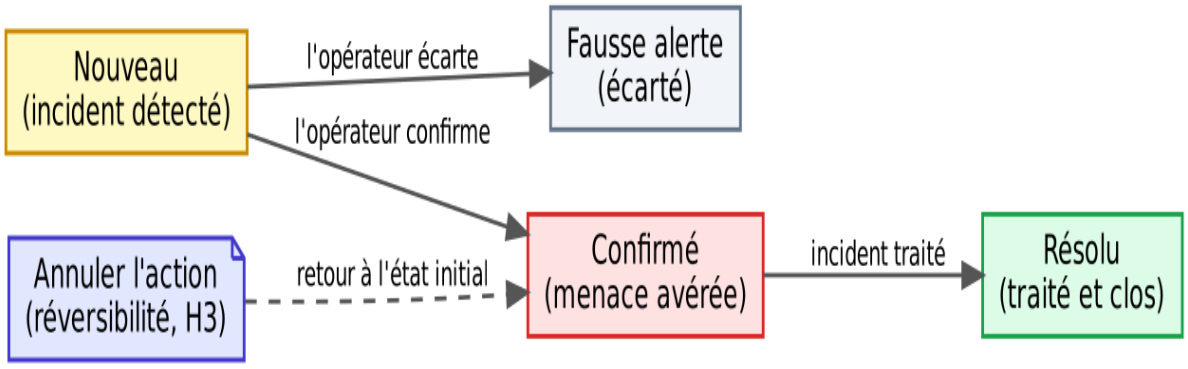


Figure 3 : Cycle de vie d'un incident, de la détection à la clôture (avec réversibilité)

2.3.1. LE MODULE DE DÉTECTION : CONFIANCE ET GRAVITÉ

Le module de détection reçoit chaque événement transmis par les sources et lui attribue deux indicateurs. Le niveau de confiance, compris entre 0 et 1, exprime la probabilité que l'événement corresponde réellement à une activité malveillante : il dépend du type d'événement et de ses caractéristiques (par exemple, le nombre de tentatives pour une attaque par force brute). Le niveau de gravité qualifie l'impact potentiel de l'événement et se décline en quatre degrés : faible, moyen, élevé et critique. Ce double indicateur permet de hiérarchiser les incidents et conditionne la décision prise à l'étape suivante.

2.3.2. LE MODULE DE DÉCISION : LA RÈGLE DE RÉPONSE AUTOMATIQUE

Le module de décision applique une règle simple et explicite. Une réponse automatique n'est déclenchée que lorsque deux conditions sont réunies simultanément : un niveau de confiance supérieur ou égal à un seuil élevé (fixé à 0,90 dans le prototype) et une gravité élevée ou critique. Lorsque ces conditions ne sont pas réunies, l'événement n'est pas traité automatiquement : il est transformé en alerte et transmis à l'opérateur pour vérification humaine. Ce seuil volontairement exigeant garantit que l'automatisation ne s'applique qu'aux cas les mieux caractérisés, ce qui limite fortement le risque d'agir sur une fausse alerte.

2.3.3. LE MODULE DE RÉPONSE : DES ACTIONS RÉVERSIBLES

Le module de réponse exécute l'action décidée. Deux types d'actions sont prévus : le blocage de la source à l'origine de l'incident et l'arrêt d'un processus suspect. Conformément à l'hypothèse H3, la réversibilité est un critère de conception : le blocage d'une source est réversible, car l'opérateur peut l'annuler et rétablir l'état initial, tandis que l'arrêt d'un processus ne l'est pas. Cette limitation est assumée et documentée ; dans le prototype, seule l'action réversible est déclenchée automatiquement, les actions non réversibles étant réservées à une décision humaine explicite.

Dans cette version de preuve de concept, l'exécution de la réponse est journalisée plutôt qu'appliquée réellement sur le réseau. Ce choix méthodologique permet de valider l'ensemble de la chaîne, de la détection à la réversibilité, sans risquer d'interrompre un trafic légitime sur l'environnement de test. Le passage à une réponse réelle est présenté parmi les perspectives d'évolution.

2.3.4. LA GESTION DES INCIDENTS : CYCLE DE VIE ET REGROUPEMENT

Chaque incident suit un cycle de vie explicite : il est d'abord créé à l'état nouveau, puis confirmé comme menace avérée ou écarté comme fausse alerte par l'opérateur, et enfin résolu lorsque son traitement est achevé. Afin de ne pas submerger l'opérateur, les événements de même nature provenant d'une même source sont regroupés en un seul incident muni d'un compteur d'occurrences, mis à jour à chaque nouvelle survenue. Cette agrégation réduit le volume d'informations à traiter et met en évidence les menaces les plus insistantes, tout en conservant l'historique complet.

2.3.5. LE TABLEAU DE BORD : L'ACCESSIBILITÉ POUR UN NON-SPÉCIALISTE

Le tableau de bord est le point de contact entre la solution et l'opérateur. Il présente la liste des incidents, chacun accompagné d'un indicateur visuel de gravité (code couleur et libellé), du nombre d'occurrences, et surtout d'une explication en langage clair : ce qui s'est passé, ce que la solution a fait, et ce que l'opérateur doit faire. Chaque incident peut être déplié pour afficher le détail et les recommandations, confirmé, écarté, ou voir son action automatique annulée.

C'est par cette présentation que la solution rend exploitables, sans expertise, des informations de sécurité habituellement réservées aux spécialistes.

2.3.6. MODÈLE DE DONNÉES DES INCIDENTS

Les incidents sont conservés dans une base de données afin d'assurer leur persistance et leur traçabilité. Chaque incident est décrit par un ensemble d'attributs : un identifiant unique, le scénario détecté, une description, la source concernée, le niveau de confiance et de gravité, la décision prise, l'action appliquée et son caractère réversible, le statut dans le cycle de vie, le nombre d'occurrences ainsi que les dates de première et de dernière survenue. Cette structure, simple mais complète, permet à la fois l'affichage sur le tableau de bord, le regroupement des événements et la constitution d'un historique exploitable pour le suivi de la sécurité.

2.3.7. FONCTIONNEMENT GLOBAL : EXEMPLE DE BOUT EN BOUT

Pour illustrer l'articulation des modules, considérons le traitement d'une attaque par force brute. Un attaquant multiplie les tentatives de connexion sur un service d'accès distant. L'IDS réseau observe ces tentatives rapprochées et génère une alerte, lue en continu par le collecteur et transmise au module de détection. Celui-ci reconnaît le scénario de force brute, lui attribue un niveau de confiance élevé (de l'ordre de 0,95) et une gravité critique.

Le module de décision constate que les deux conditions de l'automatisation sont réunies, confiance supérieure ou égale au seuil et gravité critique, et déclenche une réponse automatique réversible : le blocage de la source. Le module de gestion des incidents crée alors l'incident, l'enregistre dans la base et l'affiche sur le tableau de bord, en rouge, avec une explication en langage clair et la mention de l'action appliquée. L'opérateur, informé, peut confirmer la menace, ou, s'il s'agissait d'un test légitime, annuler le blocage en un clic pour rétablir l'état initial.

Si, à l'inverse, l'événement avait été un simple balayage de ports, de gravité élevée mais de confiance intermédiaire, la chaîne aurait abouti non pas à une réponse automatique, mais à une alerte soumise à l'opérateur. Cet exemple montre comment la solution combine rapidité d'automatisation et maintien du contrôle humain, selon la nature et la certitude de l'événement.

2.4. SÉCURISATION DES FLUX ET DES DONNÉES

La sécurisation de la solution repose sur le contrôle des accès et sur la maîtrise des réponses automatiques. L'accès au tableau de bord est protégé par une authentification, les comptes étant créés par un administrateur et les mots de passe stockés sous forme d'empreinte cryptographique (SHA-256) et jamais en clair.

Les réponses automatiques sont limitées aux cas les plus sûrs et conçues, lorsque c'est possible, pour être réversibles : une action appliquée à tort peut être annulée par l'opérateur. Les événements et les actions sont journalisés afin de conserver une trace exploitable des incidents et des réponses apportées.

2.5. CONCLUSION

Ce chapitre a présenté l'architecture fonctionnelle et les principaux mécanismes de sécurité de la solution retenue. L'organisation modulaire permet de séparer la détection, la décision, la réponse, la gestion des incidents et la présentation, tout en intégrant deux sources de détection complémentaires. L'authentification, la réversibilité des réponses et la journalisation complètent cette architecture afin d'assurer une solution à la fois fonctionnelle, maîtrisée et accessible.

DEUXIÈME PARTIE :

ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

CHAPITRE 3 : MISE EN ŒUVRE ET TESTS

DEUXIÈME PARTIE :

ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

3.1. INTRODUCTION

Ce chapitre présente l'environnement de développement et de simulation utilisé pour la réalisation de la solution, les différents composants mis en œuvre ainsi que les tests de fonctionnement et de sécurité effectués. Il permet de vérifier le comportement de la solution dans les conditions définies pour son utilisation.

3.2. ENVIRONNEMENT DE DEVELOPPEMENT ET DE SIMULATION

Afin de développer et de tester la solution sans dépendre d'une infrastructure dédiée, l'environnement suivant a été mis en place :

Détection réseau : l'IDS Suricata, installé sur le poste, analyse le trafic de l'interface réseau en temps réel ;

Détection hôte : le gestionnaire Wazuh, installé sur un système Linux (Ubuntu via WSL2), surveille les événements système (authentification, comptes, intégrité des fichiers) ;

Moteur et tableau de bord : développés en Python, avec une base de données SQLite pour la persistance des incidents et la bibliothèque Streamlit pour le tableau de bord ;

Intégration en temps réel : un collecteur lit en continu les alertes produites par Suricata et Wazuh et les injecte dans le pipeline de traitement.

Ce choix d'environnement répond à une double exigence : réalisme et accessibilité. Le recours à un système Linux exécuté via WSL2 permet de disposer d'un véritable hôte à surveiller, représentatif d'un serveur de PME, sans nécessiter de machine supplémentaire. Les outils retenus (Suricata, Wazuh, Python, une base SQLite et un tableau de bord léger) sont tous gratuits et peu gourmands en ressources, ce qui confirme la faisabilité de la solution sur le matériel courant d'une petite structure. L'ensemble reproduit, à échelle réduite, l'architecture qui serait déployée en production, où les agents seraient répartis sur les postes à surveiller et le tableau de bord rendu accessible en interne.

3.2.1. RÈGLES ET PARAMÈTRES DE DÉTECTION

La détection repose sur des règles explicites, adaptées à chaque source. Au niveau réseau, l'IDS distingue les scénarios par leurs caractéristiques observables : une tentative de connexion isolée n'est pas traitée comme une attaque, mais un nombre élevé de tentatives rapprochées sur un service d'accès distant est reconnu comme une force brute. De même, un grand nombre de connexions vers des ports différents dans un court intervalle est identifié comme un balayage

de ports. Ces seuils, fondés sur le comptage d'événements sur une fenêtre de temps, permettent de différencier un usage normal d'un comportement malveillant.

Au niveau hôte, la détection s'appuie sur les catégories d'événements remontées par le gestionnaire de sécurité : échecs d'authentification répétés, création de comptes, modification des privilèges ou altération de fichiers sensibles. Chaque catégorie est associée à un scénario, à un niveau de confiance et à une gravité. Ce paramétrage, centralisé et modifiable, permet d'adapter la sensibilité de la détection au contexte et au niveau de risque de l'organisation, conformément aux recommandations d'exploitation.

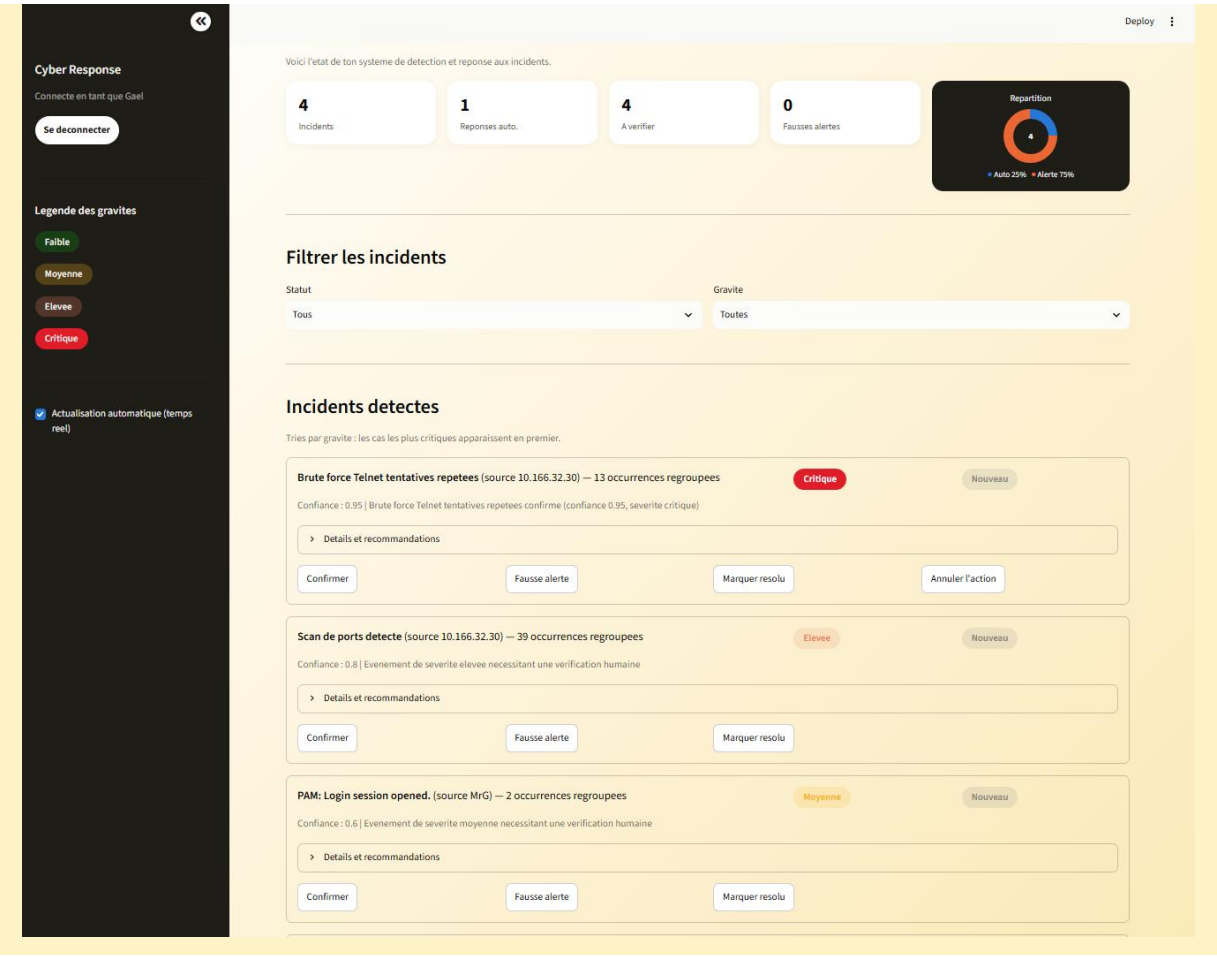


Figure 4 : Tableau de bord de la solution présentant les incidents détectés

3.3. TESTS DE FONCTIONNEMENT ET VALIDATION SECURITAIRE

Les différents composants de la solution font l'objet de tests fonctionnels et sécuritaires. Un protocole de neuf scénarios a été défini, combinant des attaques réelles détectées par Suricata et Wazuh et des actions de l'opérateur sur le tableau de bord. Les attaques réseau (ping, force brute, scan de ports) et les attaques hôte (échecs d'authentification, élévation de privilèges, création d'un compte backdoor root) sont générées de manière contrôlée afin de vérifier la

détection, la classification par gravité, la décision de réponse automatique et la réversibilité des actions.

Tableau 4 : Synthèse des scénarios de test et des réactions de la plateforme

Scénario de test	**Source de détection**	**Gravité**	**Confiance**	**Réaction de la plateforme**
Reconnaissance par requêtes ping répétées	Suricata (réseau)	Faible	0,45	Alerte simple : trafic observé, aucune réaction automatique
Force brute sur un service d'accès distant (Telnet)	Suricata (réseau)	Critique	0,95	Réponse automatique : blocage de la source, décidé et journalisé (action réversible)
Scan de ports	Suricata (réseau)	Élevée	0,80	Alerte transmise à l'opérateur pour vérification
Échecs répétés d'authentification	Wazuh (hôte)	Moyenne	0,60	Incident remonté au tableau de bord pour vérification
Élévation de privilèges (sudo vers ROOT)	Wazuh (hôte)	Critique	0,95	Décision d'arrêt du processus journalisée (exécution simulée) ; action non réversible
Création d'un compte backdoor root	Wazuh (hôte)	Critique	Non applicable	Incident critique remonté au tableau de bord

Scénario de test	Source de détection	Gravité	Confiance	Réaction de la plateforme
Annulation d'une réponse automatique par l'opérateur	Tableau de bord	Non applicable	Non applicable	Blocage annulé : retour à l'état initial vérifié
Confirmation ou rejet d'un incident par l'opérateur	Tableau de bord	Non applicable	Non applicable	Incident marqué comme menace avérée ou comme fausse alerte
Regroupement d'événements de même nature	Tableau de bord	Non applicable	Non applicable	Occurrences regroupées avec compteur (ex. ping : 20 occurrences)

Les résultats obtenus confirment que les événements sont détectés en temps réel, classés selon leur gravité, et traités conformément aux règles définies : réponse automatique réversible pour les événements de gravité élevée ou critique dont la confiance atteint le seuil fixé et dont l'action associée est réversible (blocage de la source), alerte pour vérification humaine dans les autres cas en particulier pour les incidents hôtes dont la réponse, l'arrêt d'un processus, n'est pas réversible. Dans cette preuve de concept, la réponse automatique est décidée et journalisée, son exécution réelle sur le réseau étant simulée (voir les limites, section 4.1.2).

3.3.1. SCÉNARIOS DE DÉTECTION RÉSEAU

Les scénarios réseau sont générés de manière contrôlée et détectés par l'IDS Suricata. Le scénario de reconnaissance (envoi de requêtes ping) produit un incident de faible gravité, destiné à vérifier que le trafic est bien observé sans déclencher de réaction disproportionnée. Le scénario de force brute (tentatives répétées de connexion sur un service d'accès distant) est caractérisé par un nombre élevé de tentatives rapprochées : il obtient une confiance élevée et une gravité critique, ce qui déclenche une réponse automatique réversible. Le scénario de scan de ports, enfin, est classé en gravité élevée mais avec une confiance intermédiaire, ce qui conduit à une alerte transmise à l'opérateur plutôt qu'à une réaction automatique.

3.3.2. SCÉNARIOS DE DÉTECTION HÔTE

Les scénarios hôte sont détectés par le gestionnaire Wazuh, qui surveille les journaux du système. Les échecs répétés d'authentification signalent une tentative d'accès non autorisé et remontent sous forme d'incident. La création d'un compte ou l'élévation de privilèges, actions sensibles rarement légitimes en dehors d'une administration planifiée, sont détectées et qualifiées selon leur gravité. Ces scénarios démontrent la complémentarité des deux sources : des actions invisibles sur le réseau sont repérées à l'intérieur de la machine, ce qui concrétise le principe de défense en profondeur retenu lors de la conception.

3.3.3. SCÉNARIOS DE RÉACTION ET DE RÉVERSIBILITÉ

Une troisième catégorie de tests porte sur les actions de l'opérateur et sur la réversibilité. Elle vérifie qu'une réponse automatique déclenchée sur une attaque critique peut être annulée et l'état initial rétabli, qu'un incident peut être confirmé comme menace avérée ou écarté comme fausse alerte, et que les événements de même nature sont correctement regroupés avec leur compteur d'occurrences. Ces tests valident le maintien du contrôle humain, qui constitue l'un des apports essentiels de la solution.

L'ensemble de ces scénarios confirme le comportement attendu : la détection est effective en temps réel, la classification par gravité est cohérente, la décision respecte la règle définie, et la réversibilité fonctionne. Aucune fausse réaction automatique n'a été observée sur le jeu de tests, composé uniquement de scénarios d'attaque, ce qui s'explique par le seuil de confiance exigeant retenu pour l'automatisation.

3.3.4. PROTOCOLE ET MÉTRIQUES D'ÉVALUATION

L'évaluation de la solution suit un protocole structuré en deux phases. La première phase vérifie la détection : pour chaque scénario, on contrôle que l'événement est bien repéré, classé selon la gravité attendue et affiché en temps réel sur le tableau de bord. La seconde phase vérifie les réactions : déclenchement de la réponse automatique pour les cas critiques, transmission d'une alerte pour les cas ambigus, et bon fonctionnement des actions de l'opérateur, dont la réversibilité.

Trois indicateurs guident l'évaluation. La capacité de détection mesure la proportion d'attaques effectivement repérées parmi celles générées. Le taux de fausses réactions automatiques mesure la proportion de réponses déclenchées à tort, indicateur central compte tenu de l'objectif de fiabilité. L'utilisabilité, enfin, apprécie la clarté des informations et la facilité d'action pour un

personnel non spécialisé. Sur le jeu de scénarios retenu, toutes les attaques ciblées ont été détectées, aucune réaction automatique erronée n'a été observée, et les incidents ont été présentés de manière compréhensible, ce qui valide les objectifs de détection et de décision fixés ; l'utilisabilité, elle, est appréciée à partir de la conception du tableau de bord et n'a pas fait l'objet d'un essai avec des utilisateurs.

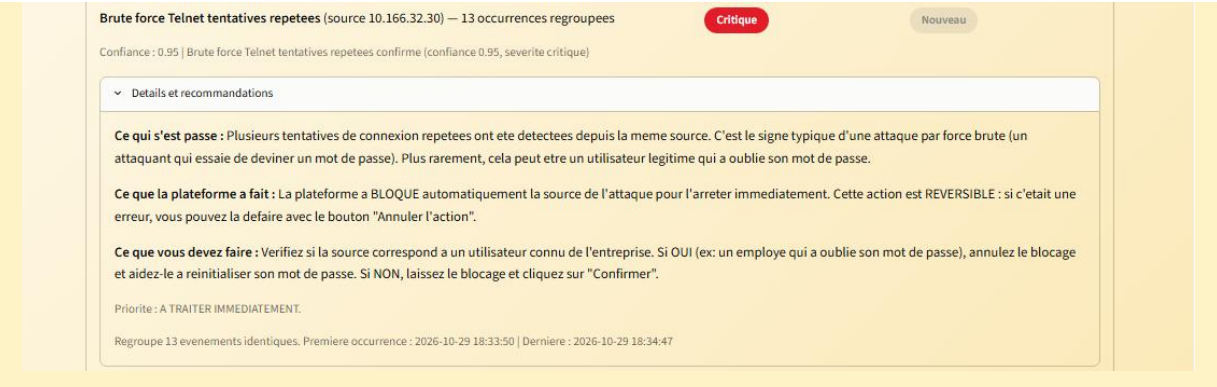


Figure 5 : Détection en temps réel d'une attaque et réponse automatique réversible

3.4. CONCLUSION

Ce chapitre a présenté l'environnement de mise en œuvre de la solution ainsi que les principaux tests fonctionnels et sécuritaires réalisés. Les essais ont porté sur la détection réseau et hôte, le calcul de la confiance et de la gravité, la décision de réponse automatique, leur réversibilité et la gestion des incidents. Les résultats obtenus permettent de vérifier le bon fonctionnement de la solution dans l'environnement de test retenu. Le chapitre suivant présente le bilan global, l'évaluation et les perspectives.

DEUXIÈME PARTIE :

ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ

CHAPITRE 4 :
RÉSULTATS, ÉVALUATION FINANCIÈRE ET PERSPECTIVES

4.1. BILAN SECURITAIRE ET OPERATIONNEL

Les résultats obtenus permettent d'établir un bilan sécuritaire et opérationnel de la solution :
Détection : les deux sources (Suricata pour le réseau, Wazuh pour les hôtes) détectent en temps réel les attaques générées et alimentent un pipeline commun ;
Classification : chaque événement est associé à un niveau de confiance et de gravité, ce qui permet de prioriser le traitement ;
Réponse automatisée réversible : pour les attaques critiques et sûrement caractérisées, une réponse automatique est décidée et journalisée son exécution étant simulée dans la preuve de concept et elle peut être annulée par l'opérateur en cas de fausse alerte ;
Accessibilité : le tableau de bord, les explications et les recommandations rendent la solution exploitable par un personnel non spécialisé ;
Réduction de la charge : le regroupement des événements de même nature et le traitement automatique des incidents répétitifs réduisent la charge de l'opérateur.

4.1.1. VALIDATION DES HYPOTHÈSES DE RECHERCHE

Les résultats obtenus permettent de revenir sur les trois hypothèses formulées en introduction. L'hypothèse H1, selon laquelle un personnel généraliste est capable d'actions de base mais limité par le temps de surveillance et d'interprétation, est étayée par la conception même de la solution, sans avoir fait l'objet d'un essai avec des utilisateurs généralistes dans le cadre de ce prototype : le tableau de bord et les recommandations en langage clair déchargent l'opérateur de l'interprétation technique, tout en lui laissant les décisions à sa portée.
L'hypothèse H2, selon laquelle le couplage de la détection et d'une réponse automatisée contrôlée permet de traiter automatiquement une partie des incidents répétitifs et bien caractérisés, est vérifiée par les tests : les attaques critiques et sûrement identifiées sont traitées sans intervention, tandis que les cas ambigus restent soumis à l'opérateur. L'hypothèse H3, enfin, selon laquelle la réversibilité des réponses concilie rapidité et contrôle, est validée par les scénarios de réversibilité, qui montrent qu'une action réversible appliquée à tort peut être annulée.

4.1.2. LIMITES DE LA SOLUTION

La solution présente des limites qu'il convient d'énoncer avec honnêteté. Dans cette version de preuve de concept, l'exécution de la réponse est simulée et journalisée, et non appliquée réellement sur le réseau. L'environnement de test repose sur une machine unique, le rôle du serveur Linux étant tenu par un système Ubuntu exécuté via WSL2, ce qui diffère d'un déploiement réel où les agents seraient répartis sur plusieurs postes. Par ailleurs, seule l'action de blocage d'une source est réversible, l'arrêt d'un processus ne l'étant pas. Enfin, la couverture de détection se limite aux scénarios définis dans le protocole de test et devrait être élargie pour un usage en production. Ces limites n'invalident pas la démarche : elles délimitent le périmètre de la preuve de concept et ouvrent sur les perspectives d'évolution.

4.2. ÉVALUATION FINANCIERE

L'évaluation financière compare les principaux postes de dépense des trois approches étudiée : la surveillance manuelle, le SIEM commercial ou SOC externalisé, et la solution open-source retenue. Cette comparaison permet d'apprécier l'intérêt économique de chaque approche dans le contexte d'une PME.

Poste de dépense	**Solution 1 : Surveillance manuelle**	**Solution 2 : SIEM commercial / SOC**	**Solution 3 : SIEM open-source retenue**
Licences logicielles	0 FCFA	Élevé (licences ou abonnement annuel)	0 FCFA (Suricata, Wazuh, Python open source)
Matériel dédié	0 FCFA	≈ 800 000 FCFA (serveur dédié)	0 FCFA (réutilisation d'un poste existant)
Expertise requise	Faible mais surveillance manuelle	Élevée prestation d'installation : ≈ 600 000 FCFA	Modérée (configuration initiale) 150 000 FCFA de temps interne valorisé
Réponse automatisée	Absente	Disponible selon l'offre	Incluse et réversible
Coût global pour une PME	≈ 400 000 FCFA, surtout en coût caché	≈ 2 600 000 FCFA	≈ 250 000 FCFA (mise en œuvre + exploitation et électricité)

Tableau 5 : Évaluation financière comparative des approches

Cette comparaison montre que la surveillance manuelle, bien que peu coûteuse, n'offre ni centralisation ni réponse automatisée, tandis que le SIEM commercial ou le SOC externalisé impliquent des coûts de licence ou d'abonnement élevés. La solution open-source retenue constitue ainsi le meilleur compromis, puisqu'elle apporte la détection et la réponse automatisée recherchées sans nécessiter de licences coûteuses.

Au-delà du seul coût d'acquisition, la comparaison doit prendre en compte le coût total de possession. La surveillance manuelle, apparemment gratuite, a un coût caché élevé : le temps passé par le personnel et le risque financier d'un incident non détecté. Le SIEM commercial ou le SOC externalisé déplacent ce coût vers des licences et des abonnements récurrents, souvent disproportionnés pour une PME. La solution retenue minimise les deux : elle réduit la charge humaine par l'automatisation et supprime les coûts de licence, ne laissant qu'un effort de configuration initiale. C'est ce rapport favorable entre le coût et le bénéfice de sécurité qui fonde sa pertinence économique pour une petite structure.

4.3. GUIDE D'EXPLOITATION, RECOMMANDATIONS ET PERSPECTIVES

4.3.1. RECOMMANDATIONS D'EXPLOITATION

Démarrer les services de détection (Suricata et Wazuh) au lancement du système afin d'assurer une surveillance continue ;

Adapter les règles de détection et les seuils de confiance au contexte et au niveau de risque de l'organisation ;

Définir une liste blanche des adresses et services critiques à ne jamais bloquer automatiquement;

Vérifier régulièrement les incidents en attente et confirmer ou annuler les actions automatiques;

Conserver et sauvegarder les journaux d'incidents afin d'en assurer la traçabilité.

4.3.2. PERSPECTIVES D'EVOLUTION

Bien que la solution réponde aux besoins essentiels identifiés, son architecture modulaire permet d'envisager plusieurs évolutions :

Le passage d'une réponse simulée à une réponse réelle, par exemple à l'aide de la fonction Active Response de Wazuh (qui applique un blocage pare-feu réversible avec expiration automatique), d'une règle de pare-feu du système, ou du mode de prévention (IPS) de Suricata;

L'ajout de nouvelles sources de détection et de nouveaux types de scénarios afin d'élargir la couverture ;

L'intégration d'un mécanisme de notification (courriel ou message) pour alerter l'opérateur en cas d'incident critique ;

L'ajout d'indicateurs et de rapports périodiques permettant de suivre l'évolution de la sécurité dans le temps.

À plus long terme, la solution pourrait intégrer des mécanismes d'apprentissage pour affiner les niveaux de confiance à partir de l'historique des incidents et des décisions de l'opérateur, et évoluer vers une véritable orchestration de la réponse (approche SOAR) adaptée aux moyens d'une PME. Ces évolutions s'appuieraient sur l'architecture modulaire déjà en place, qui a précisément été conçue pour accueillir de nouvelles sources, de nouveaux scénarios et de nouveaux actionneurs sans remettre en cause l'ensemble.

CONCLUSION GÉNÉRALE

Ce travail de mémoire, réalisé dans le cadre de la fin de notre cycle de Licence Professionnelle en Sécurité Informatique à l'ESGIS, avait pour objectif de concevoir et de mettre en œuvre un système de détection et de réponse automatisée contrôlée aux incidents de sécurité, adapté aux contraintes des petites et moyennes entreprises et utilisable par un personnel informatique non spécialisé.

Face aux limites de la surveillance manuelle habituellement observée dans les PME, nous avons conçu une solution reposant sur deux sources de détection complémentaires, l'IDS réseau Suricata et le SIEM/HIDS Wazuh, alimentant un pipeline commun de détection, de décision et de réponse. La solution calcule pour chaque événement un niveau de confiance et de gravité, décide, pour les cas les plus sûrs, d'une réponse automatique réversible dont l'exécution est simulée dans cette preuve de concept et transmet les autres à l'opérateur, tout en présentant l'information de manière claire et accompagnée de recommandations.

Les tests réalisés ont permis de valider la détection en temps réel des attaques réseau et hôte, leur classification, la décision de réponse automatique et la réversibilité des actions, l'exécution des réponses étant simulée et journalisée dans cette preuve de concept. La solution constitue ainsi une réponse accessible, peu coûteuse et maîtrisée au besoin de supervision de sécurité des PME. Son architecture modulaire permet d'envisager des évolutions, notamment le passage à une réponse réelle, l'ajout de nouvelles sources de détection et l'intégration de mécanismes de notification et de reporting.

Au terme de ce travail, la problématique posée en introduction trouve une réponse concrète : il est possible de doter une PME d'une capacité de détection et de réponse automatisée accessible à un personnel généraliste, sans coût de licence et sans expertise pointue, à condition de maîtriser l'automatisation par un seuil de décision exigeant et par la réversibilité des actions. Les trois hypothèses de recherche sont étayées par la conception et par les tests, dans le périmètre de cette preuve de concept.

Le projet ne prétend pas apporter une solution définitive. Il constitue une preuve de concept dont les limites, en particulier la simulation de la réponse et le périmètre des scénarios, ont été clairement énoncées. Ces limites tracent la voie des évolutions futures : passage à une réponse réelle et réversible, élargissement de la couverture de détection, notification des incidents critiques et suivi d'indicateurs dans le temps. Au-delà de l'outil, ce mémoire montre que des

principes de sécurité réservés aux grandes organisations peuvent être adaptés, à moindre coût, aux réalités d'une petite structure.

BIBLIOGRAPHIE

ENISA (2024). ENISA Threat Landscape 2024. European Union Agency for Cybersecurity.

MANZOOR, J., WALEED, A., JAMALI, A. F. & MASOOD, A. (2024). Cybersecurity on a budget : Evaluating security and performance of open-source SIEM solutions for SMEs. PLOS ONE, 19(3), e0301183.

NIST (2012). Computer Security Incident Handling Guide. Special Publication 800-61 Revision 2. National Institute of Standards and Technology.

NIST (2015). FIPS PUB 180-4 : Secure Hash Standard (SHS). National Institute of Standards and Technology.

WEBOGRAPHIE ET DOCUMENTATIONS TECHNIQUES

WAZUH INC. Wazuh Documentation : The Open Source Security Platform. Documentation relative à l'installation, à la configuration et aux règles de détection de Wazuh. Consulté le 29 octobre 2026 sur https://documentation.wazuh.com

OISF (Open Information Security Foundation). Suricata User Guide. Documentation relative à l'IDS/IPS Suricata, à ses règles et à son fonctionnement. Consulté le 29 octobre 2026 sur https://docs.suricata.io

PYTHON SOFTWARE FOUNDATION. Python 3 Documentation. Documentation officielle du langage Python. Consulté le 29 octobre 2026 sur https://docs.python.org/3/

STREAMLIT INC. Streamlit Documentation. Documentation relative au framework utilisé pour le tableau de bord. Consulté le 29 octobre 2026 sur https://docs.streamlit.io.

SQLITE DEVELOPMENT TEAM. SQLite Documentation. Documentation relative à la base de données SQLite utilisée pour la persistance des incidents. Consulté le 29 octobre 2026 sur https://www.sqlite.org/docs.html

ANNEXES

Les annexes regroupent les éléments techniques complémentaires permettant d'appuyer la conception et la validation de la solution : environnement de mise en œuvre, règles de détection et paramètres de la solution, et rapport synthétique des tests réalisés.

Numéro de l'annexe	Contenu
Annexe 1	Environnement de mise en œuvre de la solution
Annexe 2	Règles de détection et paramètres de la solution
Annexe 3	Rapport synthétique des tests réalisés

ANNEXE 1 : ENVIRONNEMENT DE MISE EN ŒUVRE DE LA SOLUTION

Cette annexe présente l'environnement utilisé pour la mise en œuvre et les tests de la solution. La détection réseau est assurée par l'IDS Suricata installé sur le poste, qui analyse le trafic de l'interface réseau. La détection sur les hôtes est assurée par le gestionnaire Wazuh installé sur un système Linux (Ubuntu via WSL2), qui surveille les journaux système, l'authentification, les comptes et l'intégrité des fichiers.

Le moteur de détection, de décision et de réponse ainsi que le tableau de bord ont été développés en Python, avec une base de données SQLite pour la persistance des incidents et la bibliothèque Streamlit pour l'interface. Un collecteur lit en continu les alertes de Suricata et de Wazuh et les injecte dans le pipeline.

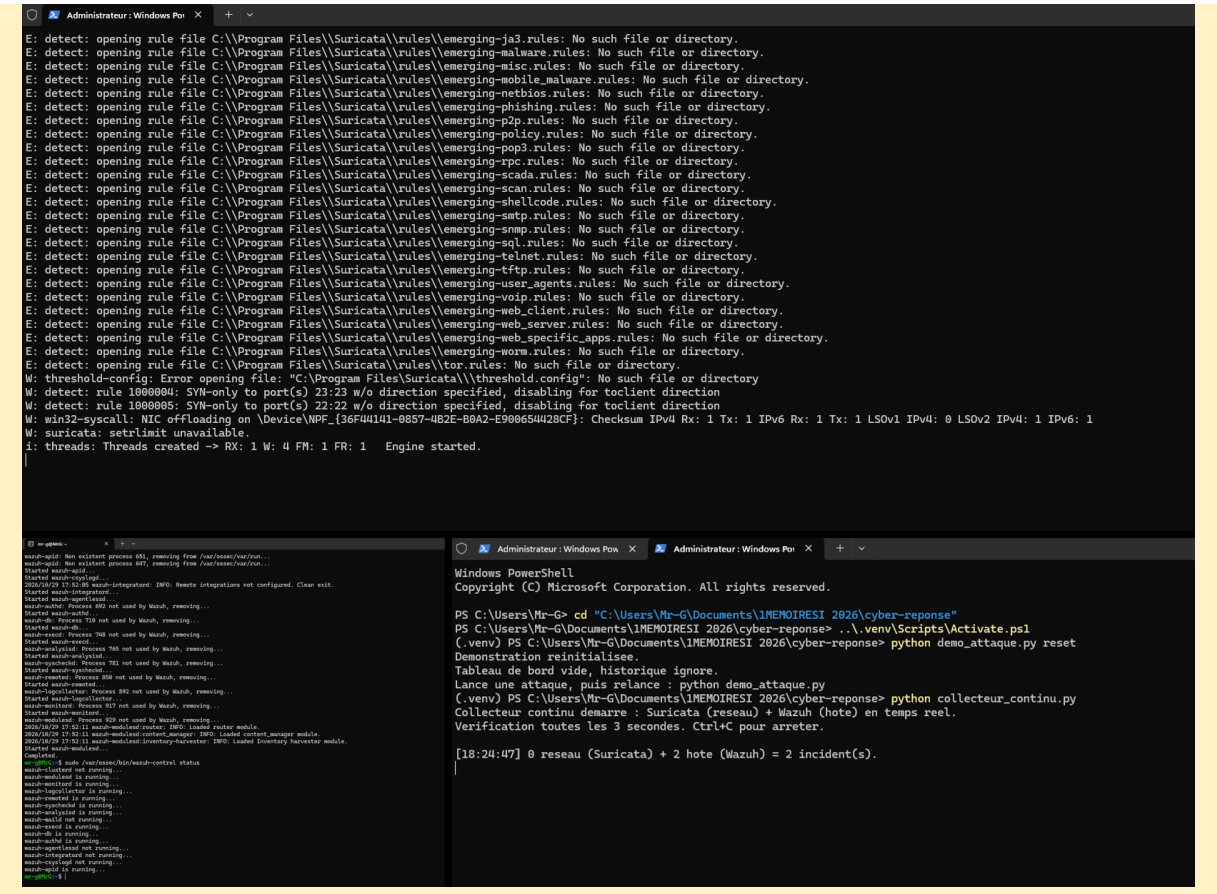


Figure 6 : Environnement de mise en œuvre de la solution

ANNEXE 2 : RÈGLES DE DÉTECTION ET PARAMÈTRES DE LA SOLUTION

Cette annexe présente les principaux paramètres de la solution.

La détection repose sur des règles appliquées aux événements collectés : règles de Suricata pour le trafic réseau (détection des pings, des tentatives de force brute et des scans de ports) et règles de Wazuh pour les événements hôte (échecs d'authentification, création de comptes, élévation de privilèges, intégrité des fichiers). Le moteur de décision déclenche une réponse automatique lorsque la confiance atteint ou dépasse le seuil fixé à 0,90 et que la gravité est élevée ou critique ; dans les autres cas, l'événement est transmis à l'opérateur pour vérification. Les valeurs de référence de ces paramètres sont regroupées dans le Tableau 6 ci-après.

Tableau 6 : Principaux paramètres de détection et de décision de la solution

Paramètre	**Valeur ou règle retenue**
Sources de détection	Suricata pour le trafic réseau, Wazuh pour les postes et serveurs
Seuil de confiance de la réponse automatique	Confiance supérieure ou égale à 0,90
Gravité requise pour la réponse automatique	Élevée ou critique
Action automatique	Blocage de la source à l'origine de l'incident (action réversible)
Action réservée à une décision humaine	Arrêt d'un processus suspect (action non réversible)
Cas ne remplissant pas les conditions	Alerte transmise à l'opérateur pour vérification humaine
Regroupement des événements	Les événements identiques sont regroupés en un seul incident muni d'un compteur d'occurrences
Cycle de vie d'un incident	Nouveau, confirmé, fausse alerte, résolu

ANNEXE 3 : RAPPORT SYNTHÉTIQUE DES TESTS RÉALISÉS

Cette annexe synthétise les principaux tests fonctionnels et sécuritaires réalisés afin de vérifier le comportement de la solution.

Composant	Rôle
Suricata	Détection des menaces sur le trafic réseau (IDS)
Wazuh	Détection des menaces sur les postes et serveurs (SIEM/HIDS)
Moteur de décision	Choix de la réponse, à partir de la confiance et de la gravité calculées par le module de détection
Module de réponse	Exécution et annulation (réversibilité) des actions
Tableau de bord	Présentation des incidents et des recommandations à l'opérateur

Tableau 7 : Rapport synthétique des tests réalisés

N°	Test réalisé	Type	Résultat attendu	Résultat obtenu	Statut
1	Reconnaissance par requêtes ping	Réseau (Suricata)	Incident de faible gravité, sans réaction automatique	Incident faible créé (confiance 0,45), occurrences regroupées	Validé
2	Force brute sur un service d'accès distant (Telnet)	Réseau (Suricata)	Incident critique et réponse automatique réversible	Blocage de la source décidé et journalisé (confiance 0,95)	Validé
3	Scan de ports	Réseau (Suricata)	Incident de gravité élevée transmis en alerte	Alerte transmise à l'opérateur (confiance 0,80)	Validé

N°	Test réalisé	Type	Résultat attendu	Résultat obtenu	Statut
4	Échecs répétés d'authentification	Hôte (Wazuh)	Incident remonté au tableau de bord	Incident de gravité moyenne remonté (confiance 0,60)	Validé
5	Élévation de privilèges (sudo vers ROOT)	Hôte (Wazuh)	Incident critique remonté	Incident critique remonté (confiance 0,95), décision journalisée	Validé
6	Création d'un compte backdoor root	Hôte (Wazuh)	Incident critique remonté	Incident critique remonté	Validé
7	Annulation d'une réponse automatique	Réversibilité	Retour à l'état initial	Blocage annulé, état initial rétabli	Validé
8	Confirmation ou rejet d'un incident par l'opérateur	Gestion des incidents	Menace confirmée ou fausse alerte écartée par l'opérateur	Fonctions de confirmation et de rejet vérifiées	Validé
9	Regroupement des occurrences d'un même événement	Gestion des incidents	Événements de même nature regroupés avec compteur	Regroupement effectif (ex. ping : 20 occurrences)	Validé

Les tests couvrent la détection réseau (ping, force brute, scan de ports), la détection hôte (échecs d'authentification, élévation de privilèges, création d'un compte backdoor root), la classification par gravité, le déclenchement et la réversibilité des réponses automatiques, ainsi que la gestion du cycle de vie des incidents sur le tableau de bord.



Figure 7 : Résultat d'un scénario de test sur le tableau de bord

TABLE DES MATIÈRES

DÉDICACES i
REMERCIEMENTS ii
SOMMAIRE iii
RÉSUMÉ iv
ABSTRACT v
GLOSSAIRE vi
LISTE DES FIGURES viii
LISTE DES TABLEAUX ix
LISTE DES PARTICIPANTS AU PROJET x
SIGLES ET ABRÉVIATIONS xi
INTRODUCTION GÉNÉRALE 1
1. CONTEXTE GÉNÉRAL 2
2. PROBLÉMATIQUE 3
3. OBJECTIFS DU MEMOIRE 3
3.1. Objectif général 3
3.2. Objectifs spécifiques 3
4. QUESTIONS ET HYPOTHESES DE RECHERCHE 4
5. IMPORTANCE ET JUSTIFICATION DU SUJET 4
6. ANNONCE DU PLAN 5
PREMIÈRE PARTIE : PRÉSENTATION ET CAHIER DES CHARGES 6
CHAPITRE 1 : PRÉSENTATIONS 7
1.1. INTRODUCTION 8
1.2. PRESENTATION DE L'ETABLISSEMENT DE FORMATION (ESGIS) 8
1.3. CONCLUSION 9
CHAPITRE 2 : CONTEXTE ET CAHIER DES CHARGES 10
2.1. INTRODUCTION 11
2.2. CONTEXTE DU PROJET : LA CYBERSÉCURITÉ DES PME 11
2.2.1. ENJEUX ET CONTRAINTES DE SÉCURITÉ DES PME 11
2.3. FONDEMENTS THÉORIQUES DE LA DÉTECTION ET DE LA RÉPONSE AUX INCIDENTS 12
2.3.1. NOTIONS FONDAMENTALES 12
2.3.2. LE CYCLE DE TRAITEMENT D'UN INCIDENT 12
2.3.3. OUTILS DE SUPERVISION DE LA SÉCURITÉ : IDS, HIDS, SIEM, SOC ET SOAR 13
2.3.4. DÉTECTION RÉSEAU ET DÉTECTION HÔTE : LA DÉFENSE EN PROFONDEUR 13

2.3.5. L'AUTOMATISATION DE LA RÉPONSE ET SA MAÎTRISE 13
2.4. ÉTUDE DE L'EXISTANT 14
2.4.1. ANALYSE DES RISQUES ET VULNERABILITES 15
2.4.2. ANALYSE CRITIQUE DE L'EXISTANT 15
2.4.3. ÉVALUATION ET CRITICITÉ DES RISQUES 16
2.5. PROBLÉMATIQUE, OBJECTIFS ET RÉSULTATS ATTENDUS 16
2.5.1. PROBLÉMATIQUE 16
2.5.2. OBJECTIFS DU PROJET 17
2.5.3. RESULTATS ATTENDUS 17
2.5.4. BESOINS FONCTIONNELS ET NON FONCTIONNELS 17
2.5.5. CONTRAINTES DU PROJET 18
2.6. CONCLUSION 18
DEUXIÈME PARTIE : ÉTUDE ET MISE EN ŒUVRE DE LA SOLUTION DE SÉCURITÉ 19
CHAPITRE 1 : APPROCHES DE SOLUTIONS 20
1.1. INTRODUCTION 21
1.2. PRÉSENTATION DES APPROCHES 21
1.2.1. SOLUTION 1 : SURVEILLANCE MANUELLE AVEC LES OUTILS NATIFS 21
1.2.2. SOLUTION 2 : SIEM COMMERCIAL OU SOC EXTERNALISÉ 22
1.2.3. SOLUTION 3 : SIEM OPEN-SOURCE À RÉPONSE AUTOMATISÉE CONTRÔLÉE (SOLUTION RETENUE) 22
1.3. SYNTHÈSE COMPARATIVE ET CHOIX DE LA SOLUTION 23
1.4. CONCLUSION 25
CHAPITRE 2 : CONCEPTION DE LA SOLUTION RETENUE 26
2.1. INTRODUCTION 27
2.2. POLITIQUE DE SÉCURITÉ DE LA SOLUTION 27
2.3. ARCHITECTURE FONCTIONNELLE DE LA SOLUTION 27
2.3.1. LE MODULE DE DÉTECTION : CONFIANCE ET GRAVITÉ 29
2.3.2. LE MODULE DE DÉCISION : LA RÈGLE DE RÉPONSE AUTOMATIQUE 29
2.3.3. LE MODULE DE RÉPONSE : DES ACTIONS RÉVERSIBLES 30
2.3.4. LA GESTION DES INCIDENTS : CYCLE DE VIE ET REGROUPEMENT ... 30

2.3.5. LE TABLEAU DE BORD : L'ACCESSIBILITÉ POUR UN NON-SPÉCIALISTE 30
2.3.6. MODÈLE DE DONNÉES DES INCIDENTS 31
2.3.7. FONCTIONNEMENT GLOBAL : EXEMPLE DE BOUT EN BOUT 31
2.4. SÉCURISATION DES FLUX ET DES DONNÉES 32
2.5. CONCLUSION 32
CHAPITRE 3 : MISE EN ŒUVRE ET TESTS 33
3.1. INTRODUCTION 34
3.2. ENVIRONNEMENT DE DEVELOPPEMENT ET DE SIMULATION 34
3.2.1. RÈGLES ET PARAMÈTRES DE DÉTECTION 34
3.3. TESTS DE FONCTIONNEMENT ET VALIDATION SECURITAIRE 35
3.3.1. SCÉNARIOS DE DÉTECTION RÉSEAU 37
3.3.2. SCÉNARIOS DE DÉTECTION HÔTE 38
3.3.3. SCÉNARIOS DE RÉACTION ET DE RÉVERSIBILITÉ 38
3.3.4. PROTOCOLE ET MÉTRIQUES D'ÉVALUATION 38
3.4. CONCLUSION 39
CHAPITRE 4 : RÉSULTATS, ÉVALUATION FINANCIÈRE ET PERSPECTIVES 40
4.1. BILAN SECURITAIRE ET OPERATIONNEL 41
4.1.1. VALIDATION DES HYPOTHÈSES DE RECHERCHE 41
4.1.2. LIMITES DE LA SOLUTION 42
4.2. ÉVALUATION FINANCIERE 42
4.3. GUIDE D'EXPLOITATION, RECOMMANDATIONS ET PERSPECTIVES 43
4.3.1. RECOMMANDATIONS D'EXPLOITATION 43
4.3.2. PERSPECTIVES D'EVOLUTION 44
CONCLUSION GÉNÉRALE 45
BIBLIOGRAPHIE I
ANNEXES II
ANNEXE 1 : ENVIRONNEMENT DE MISE EN ŒUVRE DE LA SOLUTION III
ANNEXE 2 : RÈGLES DE DÉTECTION ET PARAMÈTRES DE LA SOLUTION IV
ANNEXE 3 : RAPPORT SYNTHÉTIQUE DES TESTS RÉALISÉS V
TABLE DES MATIÈRES VIII